Mục lục

Phần I. TỔNG QUAN VỀ PFSENSE 3

1. Giới thiệu 3

2. Một số tính năng chính trong pfsense 5

3. Cài đặt Pfsense 11

4. Lợi ích của pfsense 22

PHẦN II. GIỚI THIỆU VỀ SURICATA 24

1. Giới thiệu 24

2. Lịch sử phát triển và các RFC liên quan 25

2.1. Lịch sử phát triển 25

2.2. RFC liên quan 25

3. Công nghệ áp dụng 25

3.1. Hệ thống phát hiện xâm nhập mạng IDS 25

3.2. Hệ thống ngăn chặn xâm nhập mạng IPS 26

3.3. Công nghệ giám sát an ninh mạng NSM 26

3.4. Sử dụng PCAP log lại thông tin của lưu lượng dữ liệu mạng 27

4. Luật trong Suricata 27

4.1. Định nghĩa 27

4.2. Rule Header 28

4.3. Rule Action 28

5. Kiến trúc xử lí của Suricata 45

5.1. Các quá trình xử lí 45

5.2. Ý nghĩa của từng quá trình 45
6. Ưu và nhược điểm 46
6.1. Ưu điểm 46
6.2. Nhược điểm 47
7. Cài đặt Suricata trên Pfsense 48
PHẦN III. THỰC NGHIỆM – DEMO 51
1. Mô hình 51
2. Công cụ thực hiện 51
3. Thực nghiệm 51

Lời mở đầu

Sự phát triển của công nghệ, đặc biệt là Internet đã giúp cuộc sống của con người trở nên thuận tiện và dễ dàng hơn. Nhờ có hệ thống mạng Internet ta có thể trao đổi, lưu trữ thông tin, kết nối với tất cả mọi người trên thế giới và hàng loạt lợi ích khác. Tuy nhiên trong tình hình thực tế hiện nay đặt ra khá nhiều thách thức đến từ vấn đề bảo mật, bảo vệ hệ thống mạng Internet đặc biệt là các doanh nghiệp, công ty trên thế giới. Để bảo vệ hệ thống mạng thì ta có nhiều giải pháp như sử dụng router cisco, dùng firewall cứng, firewall mềm của microsoft ... Những thiết bị như trên rất tốn kinh phí vì vậy đối với các doanh nghiệp vừa và nhỏ thì giải pháp firewall mềm mã nguồn mở là một phương án hiệu quả và ứng dụng Pfsense chính là một ví dụ điển hình. Do đó em xin chọn chủ đề nghiên cứu về **"Triển khai IDS/IPS Suricata trên Pfsense"** để tìm hiểu thêm về ứng dụng

tường lửa này và cách thức cài đặt và sử dụng công cụ Suricata trên tường lửa Pfsense.

Phần I. TỔNG QUAN VỀ PFSENSE

1. Giới thiệu

- Pfsense là một ứng dụng có chức năng định tuyến vào tường lửa mạng và miễn phí dựa trên nền tảng FreeBSD (FreeBSD là một hệ điều hành kiểu Unix được phát triển từ Unix theo nhánh phát triển của BSD dựa trên 386BSD và 4.4BSD) được cung cấp với mục đích sử dụng làm bộ định tuyến (routing) và tường lửa (firewall) rất mạnh. Pfsense được quản lý hoàn toàn qua giao diện web. Bắt đầu vào năm 2004, khi m0n0wall mới bắt đầu chập chững- đây là một dự án bảo mật tập trung vào các hệ thống nhúng Pfsense đã có hơn 1 triệu download và được sử dụng để bảo vệ các mạng ở tất cả kích cỡ, từ các mạng gia đình đến các mạng lớn của của các công ty. Ứng dụng này có một cộng đồng phát triển rất tích cực và nhiều tính năng đang được bổ sung trong mỗi phát hành nhằm cải thiện hơn nữa tính bảo mật, sự ổn định và khả năng linh hoạt của nó.

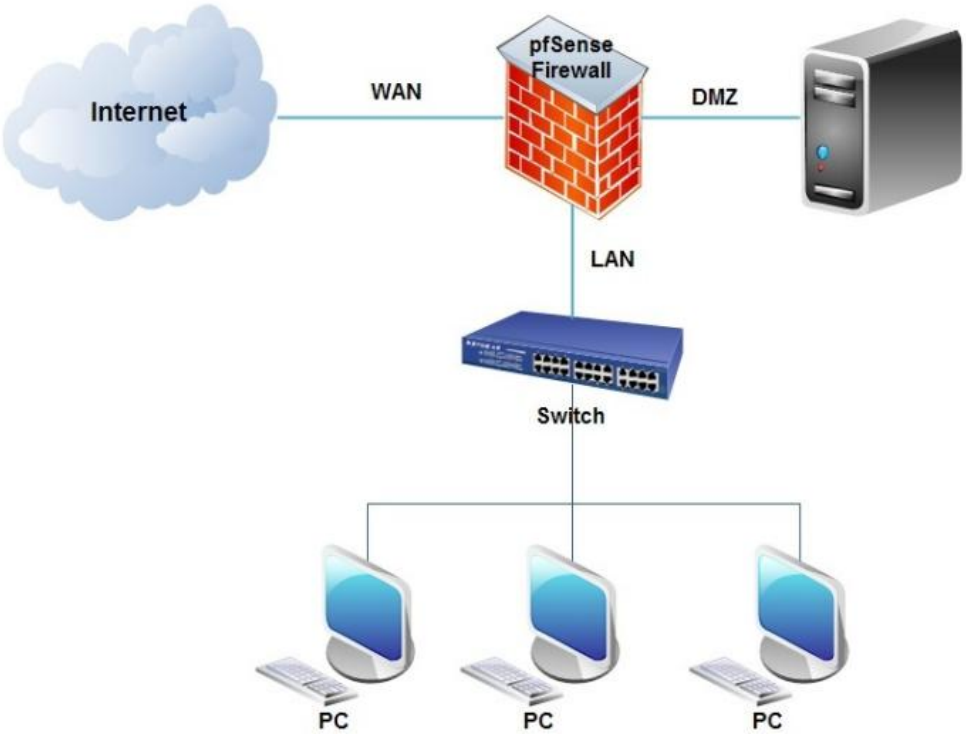
- Pfsense được dựa trên FreeBSD và giao thức Common Address Redundancy Protocol (CARP) của FreeBSD, cung cấp khả năng dự phòng bằng cách cho phép các quản trị viên nhóm hai hoặc nhiều tường lửa vào

một nhóm tự động chuyển đổi dự phòng. Vì nó hỗ trợ nhiều kết nối mạng diện rộng (WAN) nên có thể thực hiện việc cân bằng tải.

- Pfsense bao gồm nhiều tính năng đặc biệt là firewall trạng thái mà chúng ta vẫn thấy trên các thiết bị tường lửa hoặc router thương mại lớn, chẳng hạn như giao diện người dùng (GUI) trên nền Web tạo sự quản lý một cách dễ dàng. Trong khi đó phần mềm miễn phí này còn có nhiều tính năng ấn tượng đối với firewall/router miễn phí, tuy nhiên cũng có một số hạn chế.

- Pfsense hỗ trợ lọc theo địa chỉ nguồn, đích, cũng như port nguồn hay port đích hay địa chỉ IP đồng thời cũng hỗ trợ định tuyến và có thể hoạt động trong chế độ bridge hay transparent, cho phép ta chỉ cần đặt Pfsense ở giữa các thiết bị mạng mà không cần đòi hỏi việc cấu hình bổ sung. Pfsense cung cấp cơ chế NAT và tính năng chuyển tiếp cổng, tuy nhiên ứng dụng này vẫn còn một số hạn chế với Point-to-Point Tunneling Protocol (PPTP), Generic Routing Encapsulation (GRE) và Session Initiation Protocol (SIP) khi sử dụng NAT.

- Đặc điểm khá quan trọng là cấu hình để cài đặt sử dụng phần mềm Pfsense không đòi hỏi cao. Chúng ta chỉ cần một máy tính P3, Ram 128 MB, HDD 1GB cũng đủ để dựng được tường lửa Pfsense. Tuy nhiên đặc thù Pfsense là tường lửa ngăn các nguy hại giữa mạng WAN và mạng LAN nên máy cài đặt Pfsense yêu cầu tối thiểu 2 card mạng. (nhưng đối với môi trường thực tế hoặc sử dụng nâng cao, bạn có thể cần nhiều hơn 2 card mạng (ví dụ: VLAN hoặc các vùng mạng bổ sung như DMZ)).



Mô hình triển khai hệ thống với Pfsense cho doanh nghiệp vừa và nhỏ

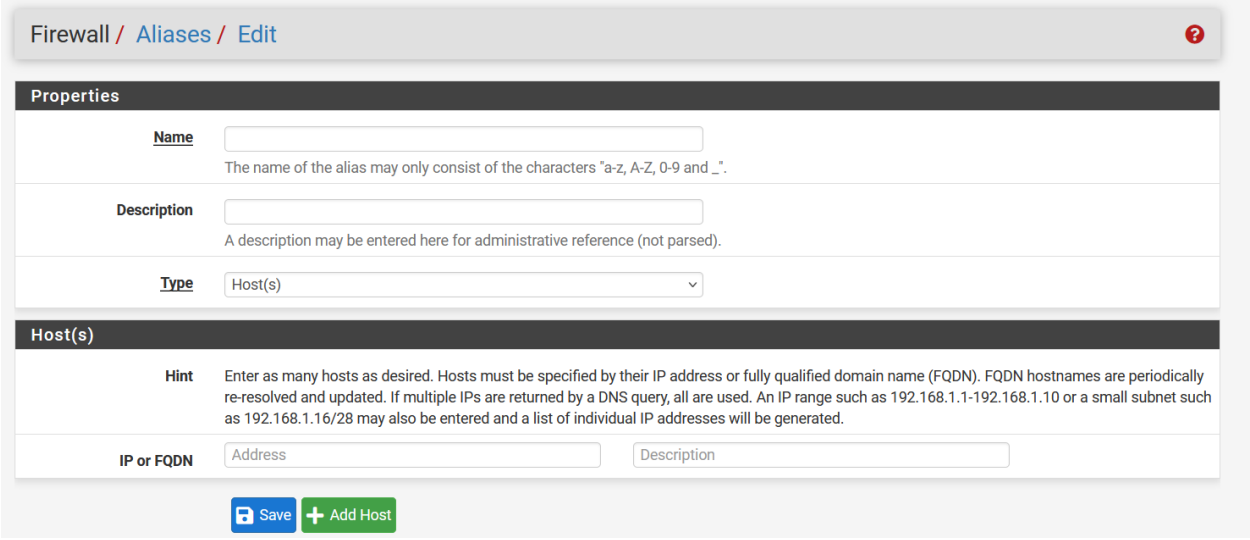
2. Một số tính năng chính trong pfsense

2.1. Aliases

- -Trong Pfsense, firewall không thể có 1 rule gồm nhiều nhóm IP hoặc 1 nhóm port. Vì vậy, điều ta cần làm là gom nhóm các IP, Port hoặc URL vào thành 1 Aliases. Một Aliases sẽ cho phép thay thế 1 host, 1 dải mạng, nhiều IP riêng biệt hay 1 nhóm port, URL, ... Aliases giúp ta tiết kiệm được phần lớn thời gian nếu bạn sử dụng một cách chính xác như thay vì sử dụng hàng loạt rule để thiết lập cho nhiều địa chỉ, ta có thể sử dụng 1 rule duy nhất để gom nhóm lại.

- Aliases là tính năng vô cùng hiệu quả của Pfsense. Một Aliases có thể định nghĩa được rất nhiều port hoặc một host hoặc nhiều dãy IP.

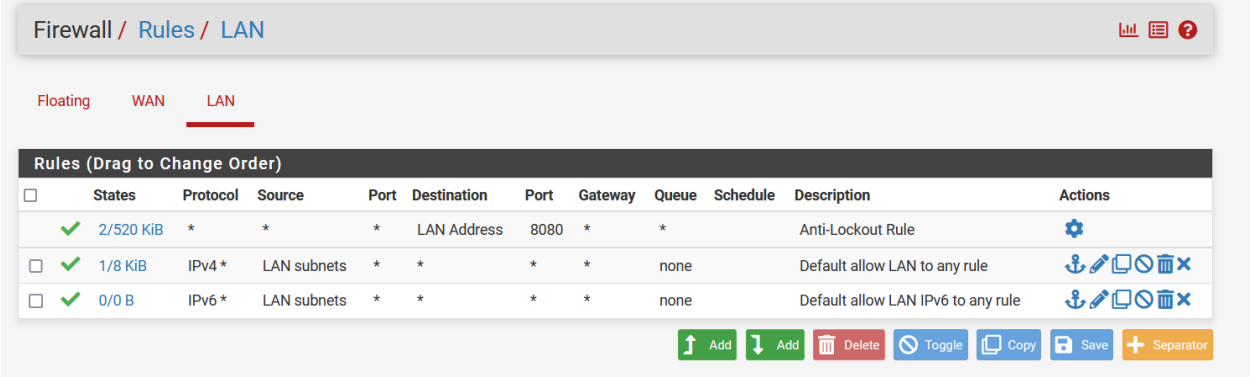
- Một ví dụ đơn giản nếu ta muốn block IP Facebook – Facebook là một dãy IP rất nhiều lớp mạng, ta không thể làm từng rule trên Firewall để chặn Facebook, nó làm ta mất rất nhiều thời gian, làm chậm hệ thống, làm khó khăn cho việc quản lý. Ta chỉ cần tạo một Aliases có tên là IP_Facebook chứa một dãy IP facebook. Sau đó trên Firewall ta chỉ cần làm một rule là chặn Aliases IP_Facebook thì sẽ block được facebook.com.

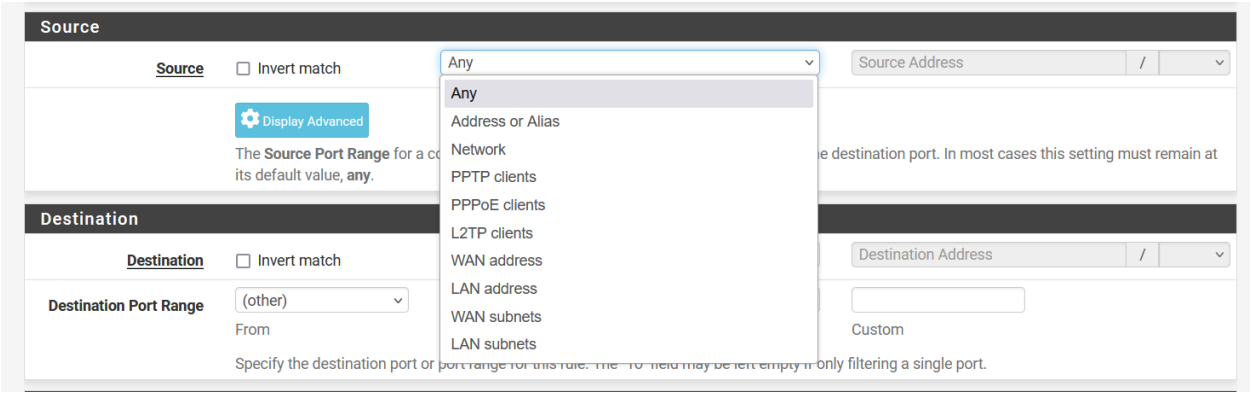


- Để vào Aliases của Pfsense, ta vào Firewall -> Aliases. Các thành phần trong Aliases:
    - Host: tạo nhóm các địa chỉ IP
    - Network: tạo nhóm các mạng
    - Port: Cho phép gom nhóm các port nhưng không cho phép tạo nhóm các protocol. Các protocol được sử dụng trong các rule

2.2. Firewall rules

- Là nơi lưu trữ tất cả các luật ra, vào trên pfsense. Để vào Rules của pfSense, ta vào Firewall -> Rules. Mặc định Pfsense cho phép mọi kết nối ra vào hệ thống, ta phải tạo các rules để quản lý mạng bên trong Firewall.





- Một số lựa chọn trong Destination và Source.
  - Any: Tất cả
  - Single host or alias: Một địa chỉ ip hoặc là một bí danh.
  - Lan subnet: Đường mạng Lan
  - Network: địa chỉ mạng
  - Lan address: Tất cả địa chỉ mạng nội bộ
  - Wan address: Tất cả địa chỉ mạng bên ngoài
  - PPTP clients: Các clients thực hiện kết nối VPN sử dụng giao thức

- PPPoE clients: Các clients thực hiện kết nối VPN sử dụng giao thức

2.3. NAT

- Pfsense có hỗ trợ NAT static dưới dạng NAT 1:1. Điều kiện để thực hiện được NAT 1:1 là ta phải có IP public. Khi thực hiện NAT 1:1 thì IP private được nat sẽ luôn ra ngoài bằng IP public tương ứng và các port cũng tương ứng trên IP public.
- Pfsense hỗ trợ NAT Outbound mặc định với Automatic outbound NAT rule generation. Để cấu hình thủ công, ta chọn Manual Outbound NAT rule generation (AON - Advanced Outbound NAT) và xóa các rule mặc định của Pfsense đi đồng thời cấu hình thêm các rule outbound.
- Ngoài 3 kiểu NAT: port forward, 1:1 và outbound, Pfsense còn hỗ trợ NAT Npt. Phương thức này thực hiện NAT đối với Ipv6.

2.4. Traffic shaper

- Đây là tính năng giúp quản trị mạng có thể tinh chỉnh, tối ưu hóa đường truyền trong pfsense. Trong pfsense, 1 đường truyền băng thông sẽ chia ra các hàng khác nhau. Có 7 loại hàng trong pfsense:
    - Hàng qACK: dành cho các gói ACK (gói xác nhận) trong giao thức TCP ở những ứng dụng chính cần được hỗ trợ như HTTP, SMTP ... . luồng thông tin ACK tương đối nhỏ nhưng lại rất cần thiết để duy trì tốc độ lưu thông lớn.
    - Hàng qVoIP: dành cho những loại lưu thông cần đảm bảo độ trễ nghiêm ngặt, thường dưới 10ms như VoIP, video conferences.

- Hàng qGames: dành cho những loại lưu thông cần đảm bảo độ trễ rất chặt chẽ, thường dưới 50ms như SSH, game online
- Hàng qOthersHigh: dành cho các loại ứng dụng quan trọng có tính tương tác rất cao, cần đáp ứng nhanh, cần độ trễ thấp như: NTP, DNS, SNMP
- Hàng qOthersDefault: dành cho các giao thức ứng dụng quan trọng có tính tương tác vừa, cần độ đáp ứng nhất định như HTTP, IMAP ...
- Hàng qOthersLow: dành cho các giao thức ứng dụng quan trọng nhưng có tính tương tác thấp như SMTP, POP3, FTP
- Hàng qP2P: dành cho cho các ứng dụng không tương tác, không cần đáp ứng nhanh như bittorrent

- Mặc định trong pfsense, các hàng sẽ có độ ưu tiên từ thấp đến cao: qP2P < qOthersLow < qOthersDefault < qOthersHigh < qGames < qACK < qVoIP.

- Ta có thể chỉnh lại độ ưu tiên priority cũng như dung lượng băng thông bandwidth mặc định mà các hàng chiếm để nâng cao băng thông cho các hàng tương ứng.

- Pfsense cũng hỗ trợ giới hạn tốc độ download/upload của 1 IP hoặc 1 dải IP với ta thiết lập thông số tại phần limiter. Firewall Pfsense hỗ trợ chặn những ứng dụng chạy trên layer 7 – application trong mô hình OSI như sip, ftp, http ... trong phần Layer 7.

2.5. VPN

- Một tính năng khác không thể thiếu đối với các gateway là VPN. VPN (Virtual Private Network) là một kiểu kết nối cho phép các máy tính truyền thông với nhau thông qua một môi trường chia sẻ như mạng Internet nhưng vẫn đảm bảo được tính riêng tư và bảo mật dữ liệu. Để cung cấp kết nối giữa các máy tính, các gói thông tin được bao bọc bằng một header có chứa những thông tin định tuyến, cho phép dữ liệu có thể gửi từ máy truyền qua môi trường mạng chia sẻ và đến được máy nhận, như truyền trên các đường ống riêng được gọi là tunnel. Để bảo đảm tính riêng tư và bảo mật trên môi trường chia sẻ này, các gói tin được mã hoá và chỉ có thể giải mã với những khóa thích hợp, ngăn ngừa trường hợp "trộm" gói tin trên đường truyền. Chức năng này của pfSense được đánh giá là rất tốt.

Pfsense cũng hỗ trợ VPN qua 4 giao thức: IPSec, L2TP, PPTP và OpenVPN

Pfsense có rất nhiều plugin hỗ trợ monitor băng thông. Sau đây là 1số plugin thông dụng:

- **RRD Graphs**
  - Đây là tool mặc định có sẵn khi cài pfsense. Với RRD graphs, ta có thể theo dõi được trạng thái của server: memory, process ... hay với băng thông của các đường truyền LAN, WAN ...
  - Một nhược điểm của RRD Graphs là không theo dõi được dung lượng từng IP.
- **Lightsquid**
  - Lightsquid là package hỗ trợ xem report trên pfsense sau khi đã cài gói squid.

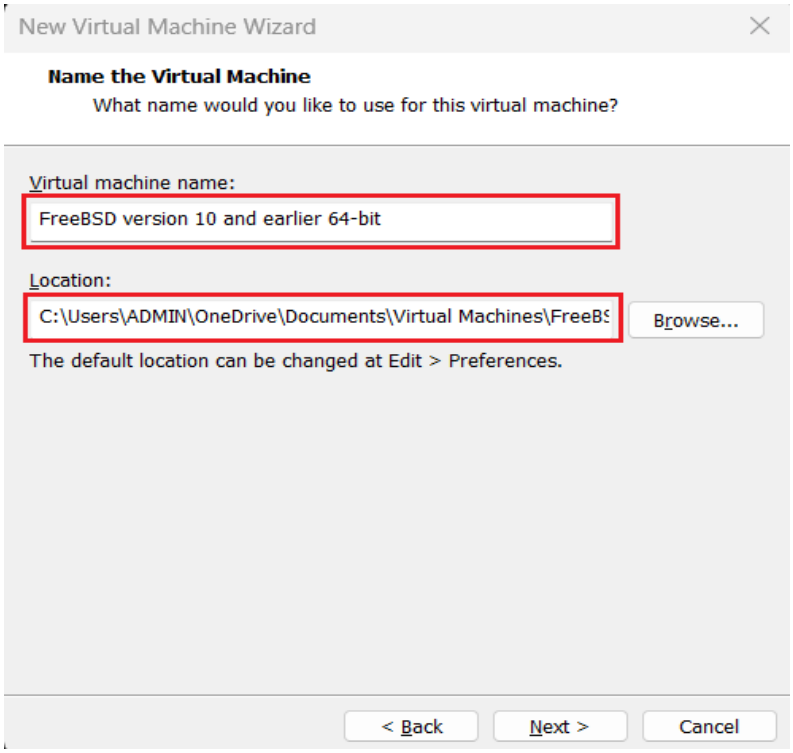
    - Với Lightsquid, ta có thể check dung lượng mỗi IP sử dụng theo ngày. Tổng dung lượng ngày hôm đó sử dụng hay các trang web đã vào ...
- **BandwidthD**
    - 1 plugin nữa có thể monitor dung lượng sử dụng của IP là BandwidthD.
    - BandwidthD thống kê dữ liệu theo từng IP, dung lượng gửi, nhận, các giao thức sử dụng như FTP, HTTP ...
- **Ntop**
    - 1 plugin thường được sử dụng nữa là Ntop. Với Ntop, ta có thể theo dõi băng thông hiện tại IP nào sử dụng lớn nhất, dung lượng tải của cổng, kết nối tới internet ...

3. Cài đặt Pfsense

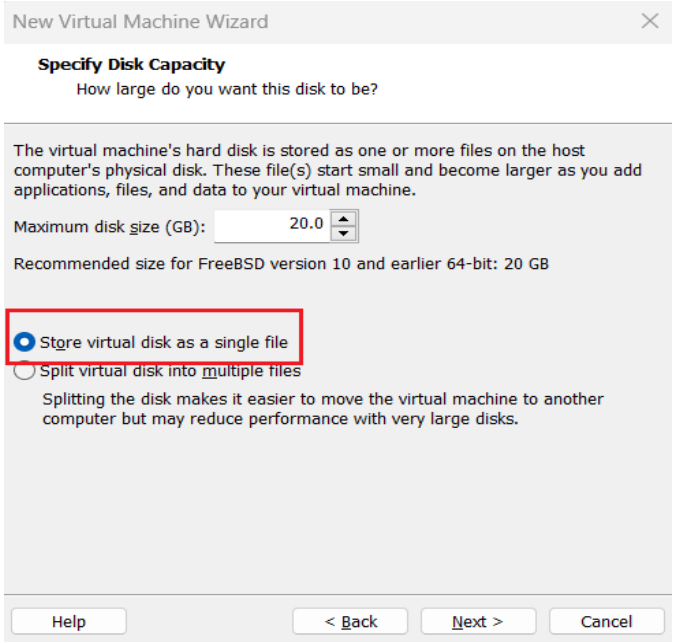
- Chuẩn bị:
    - Yêu cầu phần cứng tối thiểu để cài đặt Pfsense là: CPU 600 MHz, RAM 512 MB, ổ cứng 4 GB và có USB boot hoặc đĩa CD/DVD để cài đặt ban đầu.
- Các bước cài đặt:
    - Vào VMware Workstation Pro và chọn File rồi chọn New Virtual Machine....

- Chọn vị trí file *.iso : tùy chỉnh đường dẫn

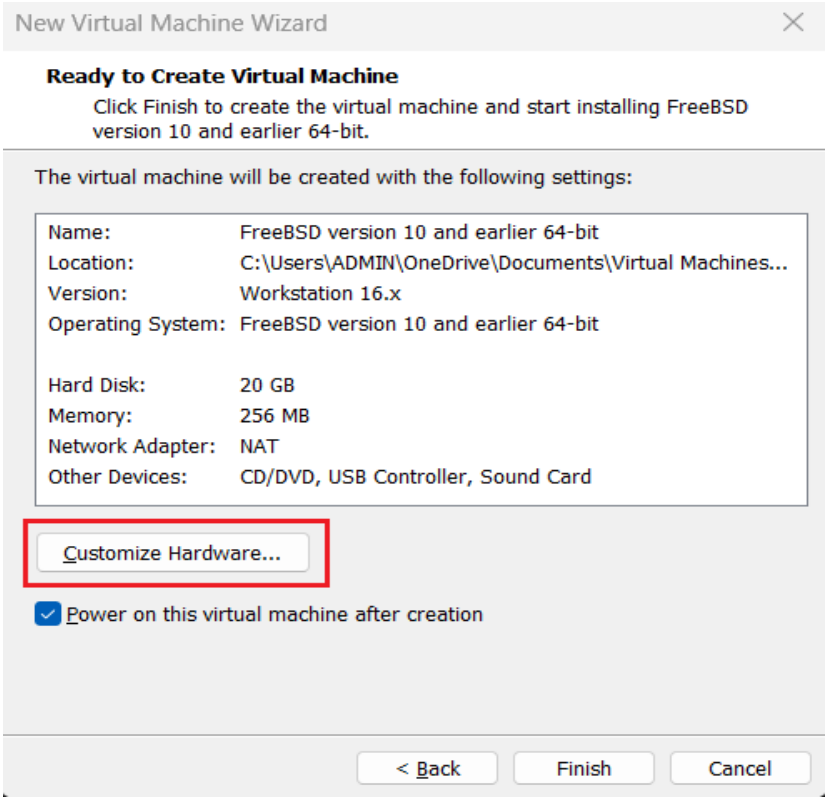
- Tùy chọn tên và vị trí lưu trữ cho máy ảo - Tùy chọn dung lượng ổ cứng ảo



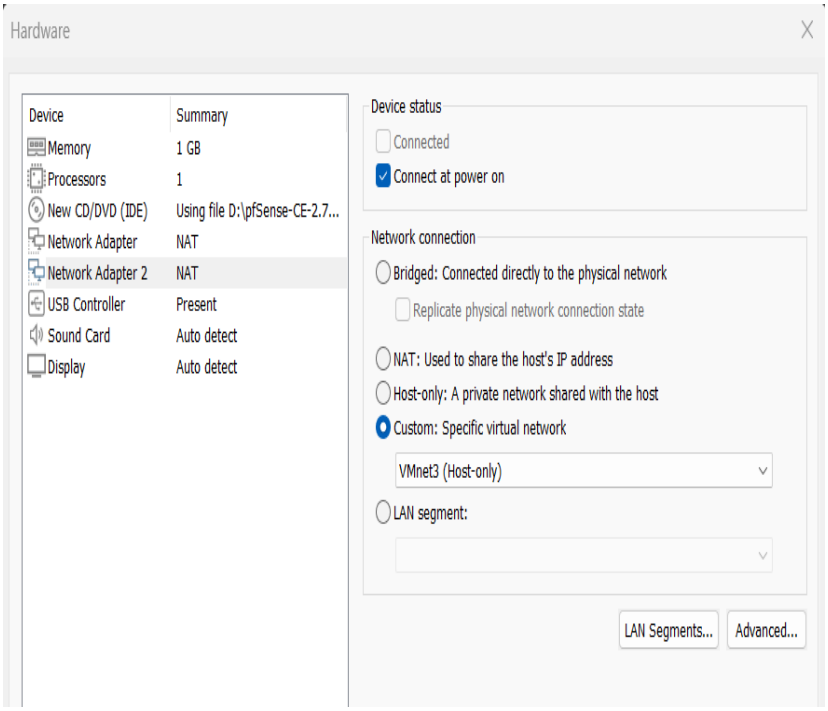
- Chọn single file và “Next”.



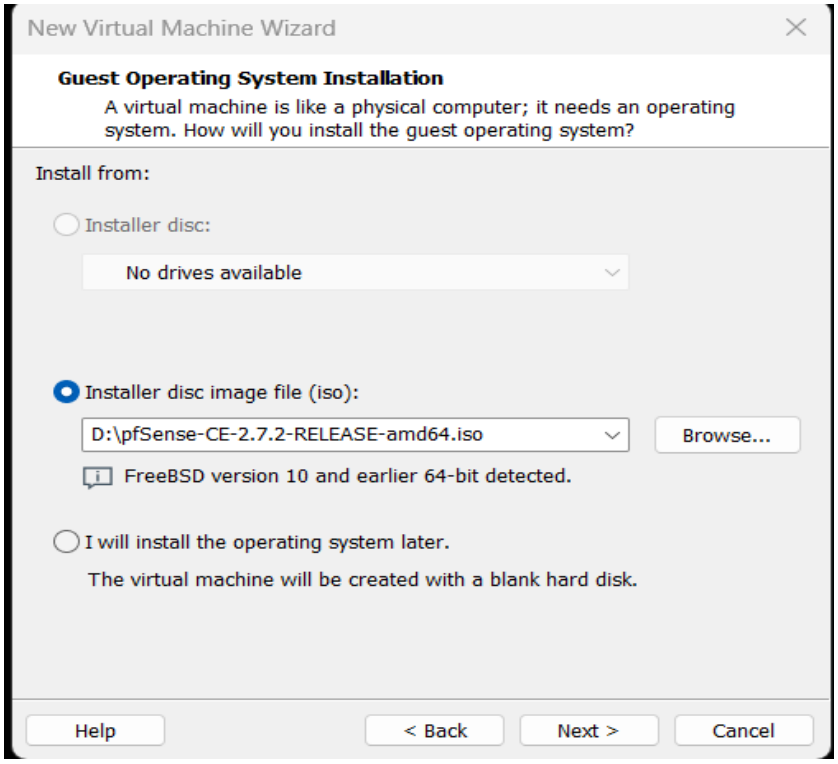
- Chọn “Customize Hadware...” và điều chỉnh lại Processor và Ram phù hợp



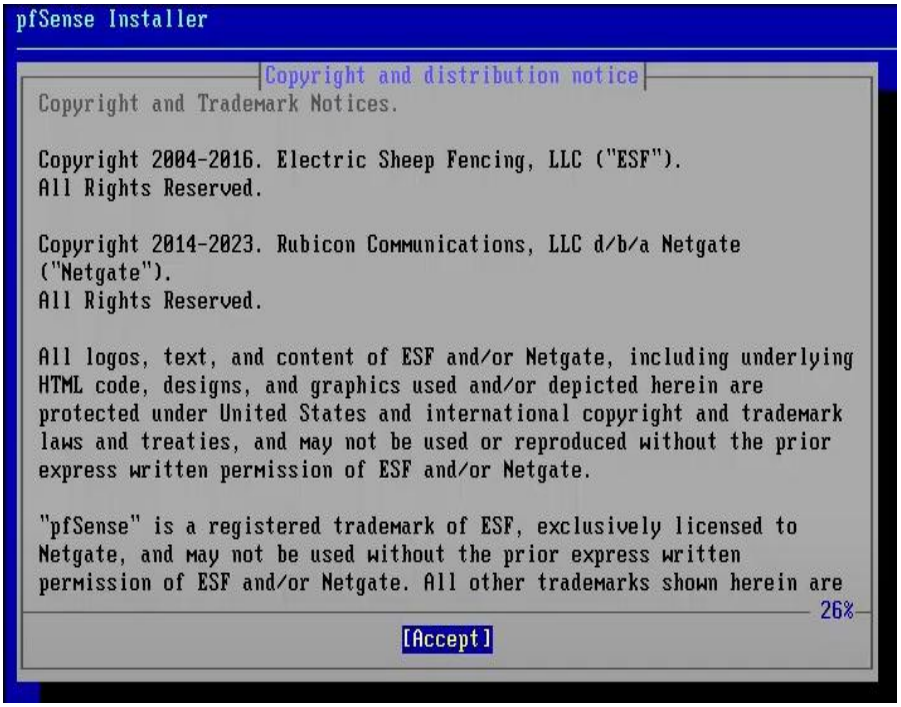
- Phần Network:
  - Thêm 1 Adapter: Add -> Adapter
  - Network Adapter (1): NAT (là WAN)
  - Network Adapter (2): Vmnet3 (là LAN)



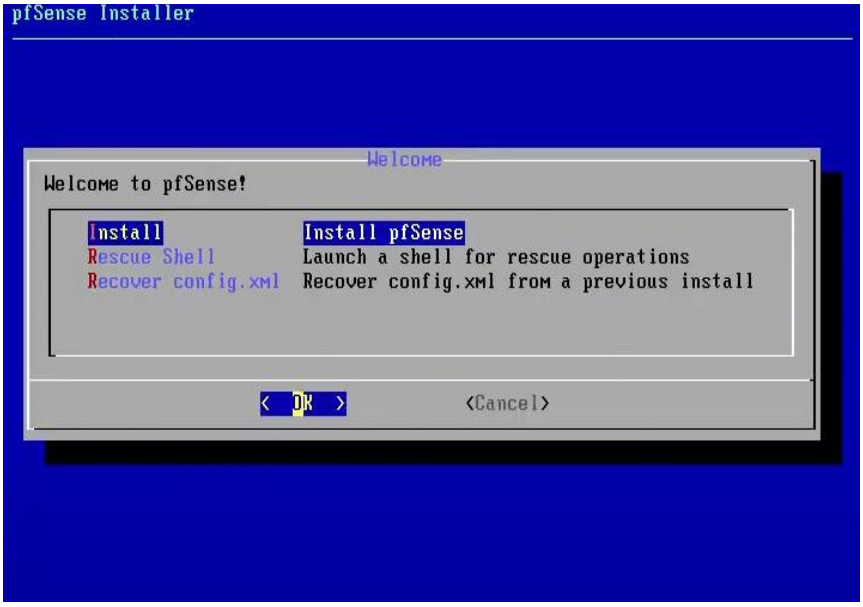
- Hoàn tất và khởi chạy máy ảo để bắt đầu cài đặt



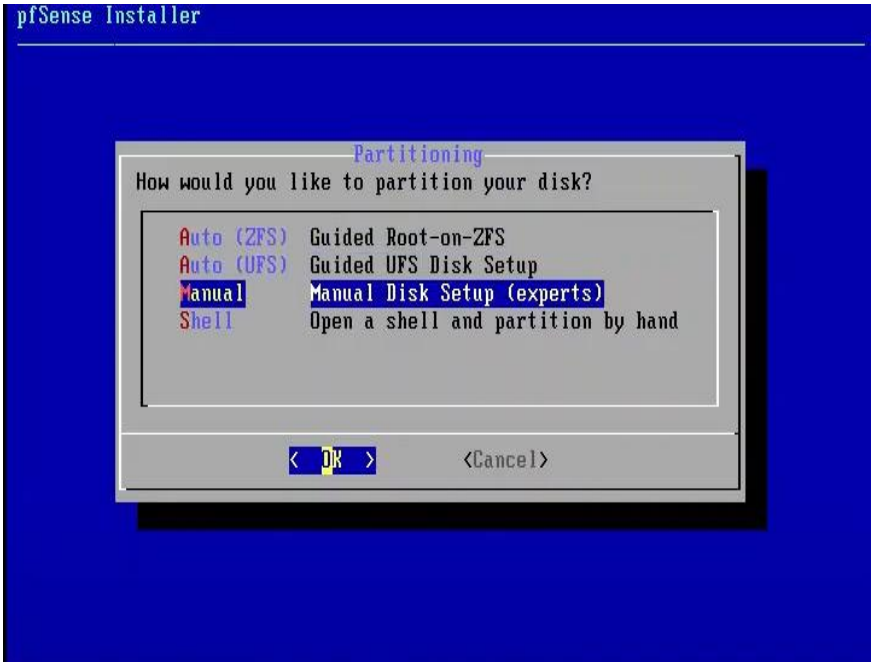
- Khởi chạy máy ảo pfsense vừa cài đặt
- Quá trình cài đặt pfsense:
  - Xem các điều khoản sử dụng, “Accept”.



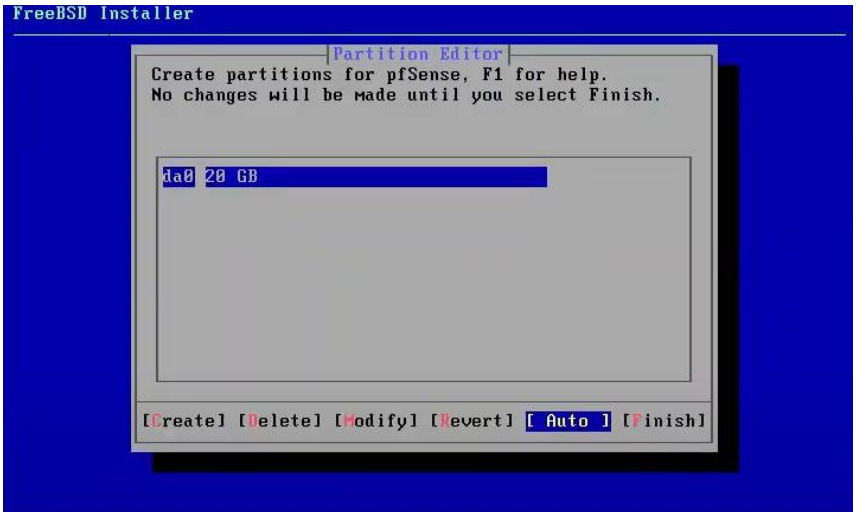
- Cài đặt: Chọn “Install”



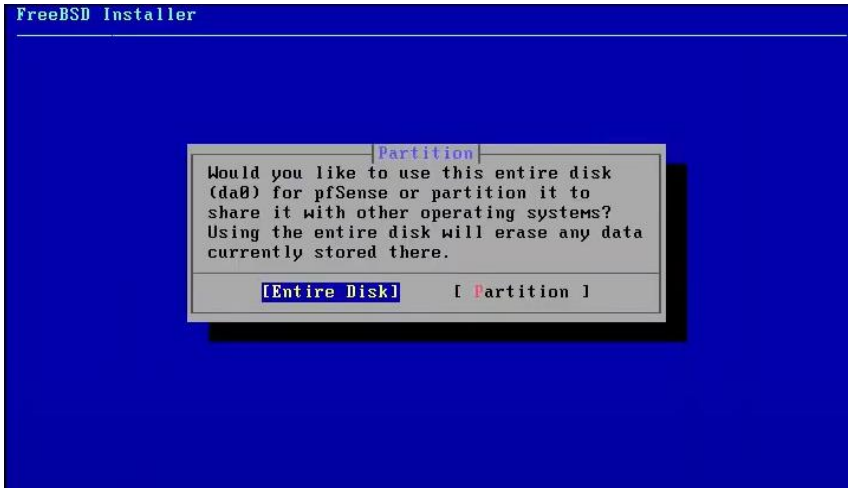
- Chọn cách thức phân vùng
  - Chọn Manual



- Auto



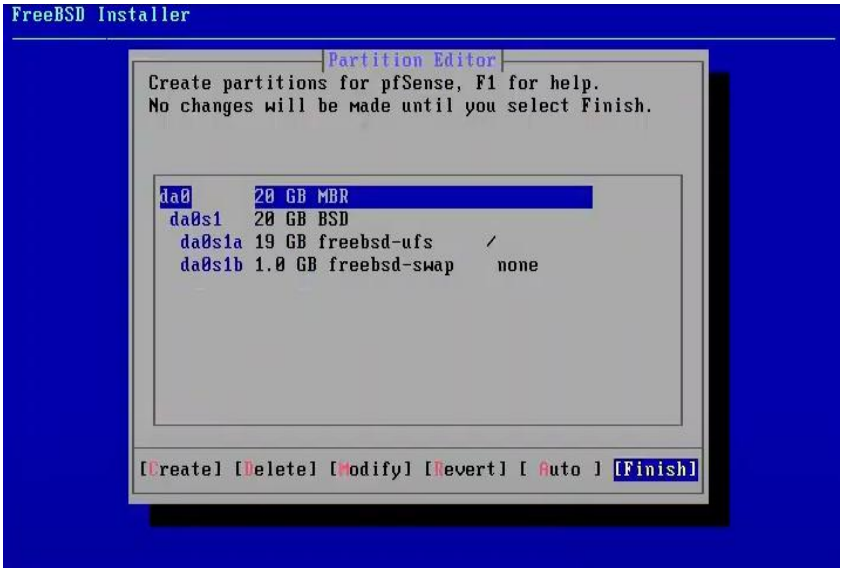
- Entire Disk


FreeBSD Installer
Partition
Would you like to use this entire disk (da0) for pfSense or partition it to share it with other operating systems? Using the entire disk will erase any data currently stored there.
[Entire Disk]
[Partition]

- MBR

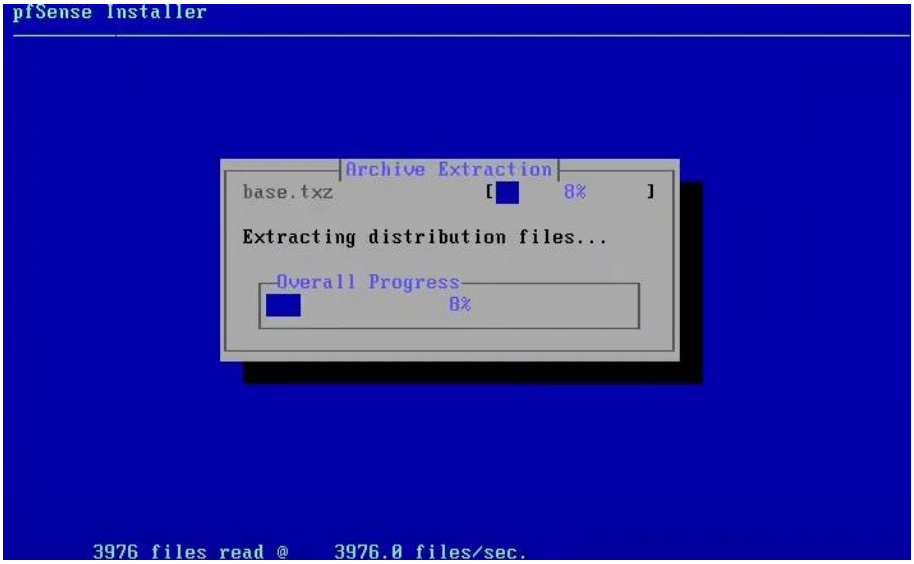
FreeBSD Installer
Partition Scheme
Select a partition scheme for this volume:
APM Apple Partition Map
BSD BSD Labels
GPT GUID Partition Table
MBR DOS Partitions
[OK]
[Cancel]

- Finish



- Commit

- Quá trình cài đặt bắt đầu, hoàn tất sẽ Reboot

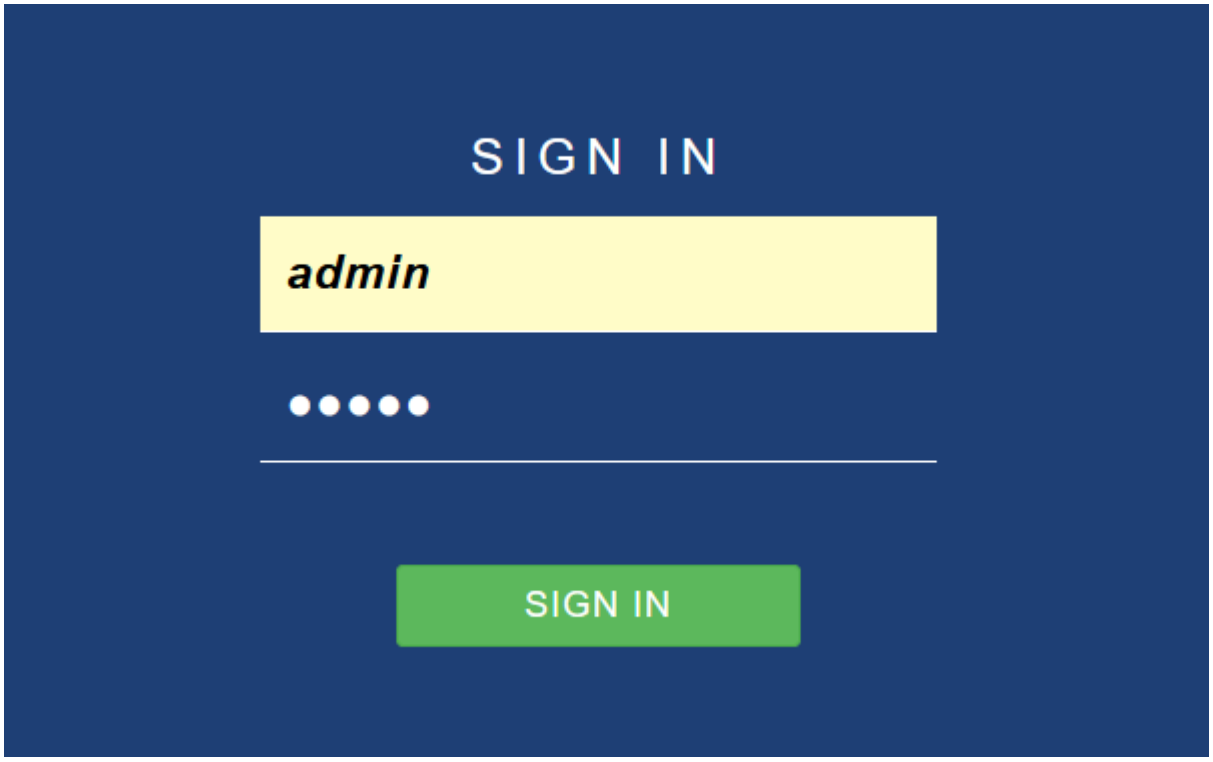


- Cấu hình ban đầu (trên console)
    - Thiết lập lại ip của LAN: Chọn 2 (set IP ...)
    - Nhấn tiếp 2 (LAN) -> Đặt IP mới và tiếp tục

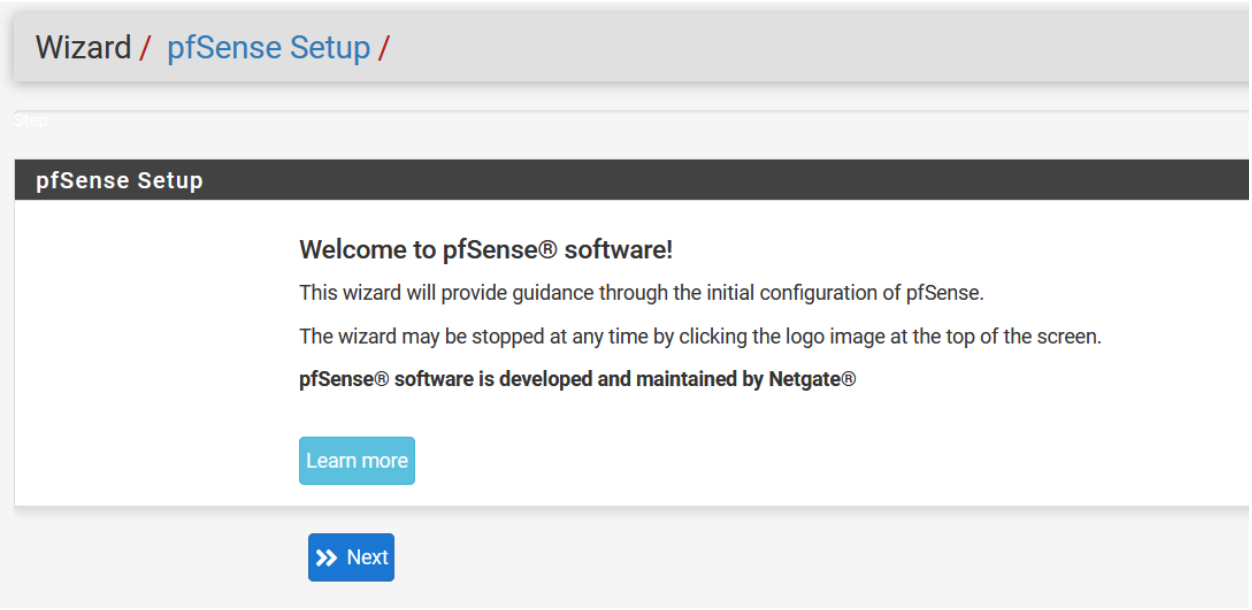
```
 6) Halt system                      15) Restore recent configuration
 7) Ping host                        16) Restart PHP-FPM
 8) Shell

Enter an option: 2

Available interfaces:

1 - WAN (em0 - dhcp, dhcp6)
2 - LAN (em1 - static)

Enter the number of the interface you wish to configure: 2

Configure IPv4 address LAN interface via DHCP? (y/n) n

Enter the new LAN IPv4 address.  Press <ENTER> for none:
> 192.168.1.10
```

Truy cập: http://192.168.1.10

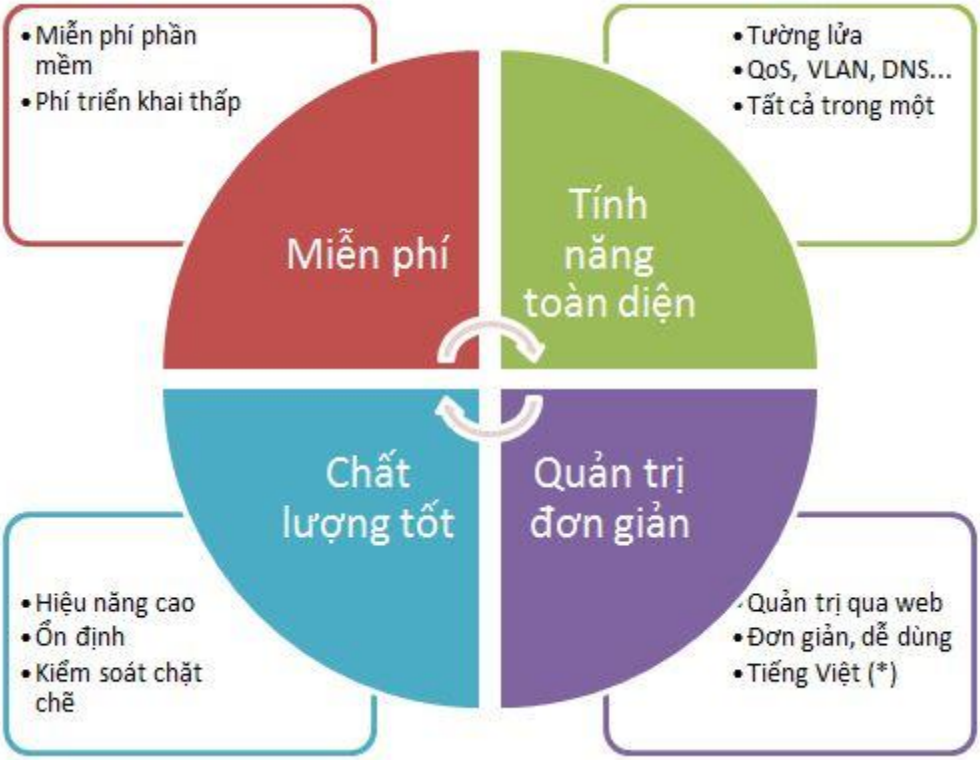
Đăng nhập mặc định : admin/pfsense



Thành công đăng nhập vào pfsense.



4. Lợi ích của pfsense



Lợi ích của pfsense

- Hoàn toàn miễn phí, giá cả là ưu thế vượt trội của tường lửa Pfsense. Tuy nhiên, rẻ không có nghĩa là kém chất lượng, tường lửa Pfsense hoạt động cực kỳ ổn định với hiệu năng cao, đã tối ưu hóa mã nguồn và cả hệ điều hành. Cũng chính vì thế, Pfsense không cần nền tảng phần cứng mạnh.
- Nếu doanh nghiệp không có đường truyền tốc độ cao, tường lửa Pfsense chỉ cần cài đặt lên một máy tính cá nhân là có thể bắt đầu hoạt động.

- Điều đó càng góp phần làm giảm chi phí triển khai, đồng thời tạo nên sự linh hoạt, tính mở rộng/sẵn sàng chưa từng có, khi doanh nghiệp muốn có nhiều hơn một tường lửa.
- Không chỉ là một tường lửa, Pfsense hoạt động như một thiết bị mạng tổng hợp với đầy đủ mọi tính năng toàn diện sẵn sàng bất cứ lúc nào. Khi có một vấn đề về hệ thống mạng phát sinh, thay vì phải loay hoay tìm thiết bị và mất thời gian đặt hàng, doanh nghiệp có thể kết hợp các tính năng đa dạng trên Pfsense để tạo thành giải pháp hợp lý, khắc phục sự cố ngay lập tức.
- Không kém phần quan trọng đó là khả năng quản lý. Tường lửa Pfsense được quản trị một cách dễ dàng, trong sáng qua giao diện web.

-> Tường lửa Pfsense là sự kết hợp hoàn hảo và mạnh mẽ, đem lại sự hợp lý cho các nhà tài chính, và sự tin tưởng cho các nhà quản trị.

PHẦN II. GIỚI THIỆU VỀ SURICATA

1. Giới thiệu

Suricata là một hệ thống phát hiện xâm nhập dựa trên mã nguồn mở. Nó được phát triển bởi Open Information Security Foundation (OISF).

Công cụ này được phát triển không nhằm cạnh tranh hay thay thế các công tụ hiện có, nhưng nó sẽ mang lại những ý tưởng và công nghệ mới trong lĩnh vực an ninh mạng.

Suricata là công cụ IDS/IPS (Intrusion Detection System / Intrusion Prevention System) phát hiện và ngăn chặn xâm nhập dựa trên luật để theo dõi lưu lượng mạng và cung cấp cảnh báo đến người quản trị hệ thống khi có sự kiện đáng ngờ xảy ra. Nó được thiết kế để tương thích với các thành phần an ninh mạng hiện có. Bản phát hành đầu tiên chạy trên nền tảng linux 2.6 có hỗ trợ nội tuyến (inline) và cấu hình giám sát lưu lượng thụ động có khả năng xử lý lưu lượng lên đến gigabit. Suricata là công cụ IDS/IPS miễn phí trong khi

nó vẫn cung cấp những lựa chọn khả năng mở rộng cho các kiến trúc an ninh mạng phức tạp nhất.

Là một công cụ đa luồng, Suricata cung cấp tăng tốc độ và hiệu quả trong việc phân tích lưu lượng mạng. Ngoài việc tăng hiệu quả phần cứng (với phần cứng và card mạng giới hạn), công cụ này được xây dựng để tận dụng khả năng xử lý cao được cung cấp bởi chip CPU đa lõi mới nhất.

2. Lịch sử phát triển và các RFC liên quan

2.1. Lịch sử phát triển

Vào tháng 12 năm 2009, một phiên bản beta đã được phát hành. Bản chuẩn đầu tiên phát hành tiếp theo vào tháng 7 năm 2010.

2.2. RFC liên quan

Jonkman, Matt (2009-12-31). "Suricata IDS Available for Download!". Seclists.org. Retrieved 2011-11-08.

"Suricata Features". Retrieved 2012-10-06.

"Suricata All Features". Retrieved 2012-10-06.

3. Công nghệ áp dụng

3.1. Hệ thống phát hiện xâm nhập mạng IDS

- IDS (Intrusion Detection System) là hệ thống giám sát lưu thông mạng (có thể là phần cứng hoặc phần mềm), có khả năng nhận biết những hoạt động khả nghi hay những hành động xâm nhập trái phép trên hệ thống mạng trong tiến trình tấn công, cung cấp thông tin nhận biết và

đưa ra cảnh báo cho hệ thống, nhà quản trị. IDS có thể phân biệt được các cuộc tấn công từ nội bộ hay tấn công từ bên ngoài.

- IDS phát hiện dựa trên các dấu hiệu đặc biệt về nguy cơ đã biết hay dựa trên so sánh lưu thông mạng hiện tại với baseline (thông số chuẩn của hệ thống có thể chấp nhận được) để tìm ra các dấu hiệu bất thường.

3.2. Hệ thống ngăn chặn xâm nhập mạng IPS

- IPS (Intrusion Prevention System) là một hệ thống có thể phát hiện và ngăn chặn sự xâm nhập từ bên ngoài vào các hệ thống máy tính.
- IPS là một phương pháp tiếp cận an ninh mạng bằng cách ưu tiên sử dụng các công nghệ tiên tiến để phát hiện và ngăn chặn các nỗ lực xâm nhập vào hệ thống máy tính. IPS kiểm tra các luồng lưu lượng ra/ vào một hệ thống máy tính hoặc mạng máy tính nhằm mục đích vi phạm an ninh. Nếu phát hiện mối đe dọa thì nó sẽ có những hành động bảo vệ như ngăn chặn gói tin hoặc ngắt toàn bộ kết nối. IPS kiểm tra, ghi chép lại một cách chi tiết các hành động đang đăng nhập vào hệ thống và gửi cảnh báo cho hệ thống hoặc quản trị mạng. Các IPS khác nhau có phương thức khác nhau trong việc kiểm tra các luồng dữ liệu để phát hiện các mối đe dọa, xâm nhập.

3.3. Công nghệ giám sát an ninh mạng NSM

Giám sát an ninh mạng (Network Security Mornitoring) là việc thu thập các thông tin trên các thành phần của hệ thống, phân tích các thông tin, dấu hiệu nhằm đánh giá và đưa ra các cảnh báo cho người quản trị hệ thống.

Đối tượng của giám an ninh mạng là tất cả các thành phần, thiết bị trong hệ thống mạng:

- Các máy trạm

- Cơ sở dữ liệu

- Các ứng dụng

- Các server

- Các thiết bị mạng

3.4. Sử dụng PCAP log lại thông tin của lưu lượng dữ liệu mạng

PCAP (packet capture) bao gồm những giao diện lập trình ứng dụng (API) dùng để chặn bắt và phân tích các lưu lượng dữ liệu trên mạng. PCAP thực hiện các chức năng lọc gói dữ liệu theo những luật của người dùng khi chúng được truyền tới ứng dụng, truyền những gói dữ liệu thô tới mạng, thu thập thông tin thống kê lưu lượng mạng. Đối với các hệ thống thuộc họ Unix ta có thư viện libpcap, còn đối với Window ta có thư viện được port từ libpcap là winpcap.

4. Luật trong Suricata

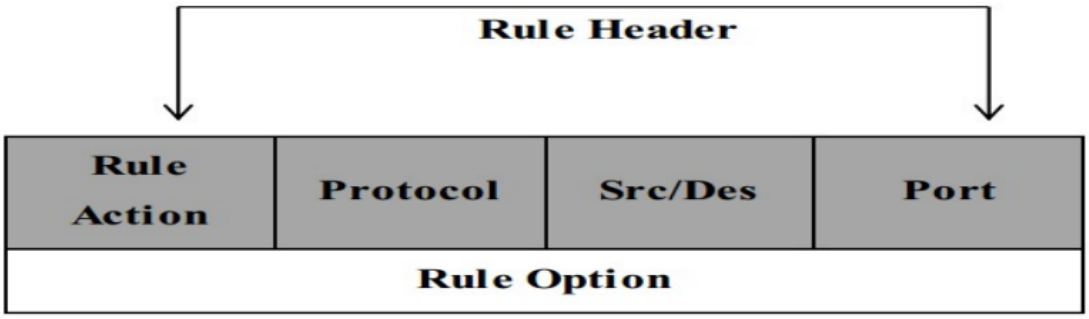
4.1. Định nghĩa

"Luật" (Rule) trong Suricata ta có thể hiểu một cách đơn giản nó giống như các quy tắc và luật lệ trong thế giới thực. Nghĩa là nó sẽ có phần mô tả một trạng thái và hành động gì sẽ xảy ra khi trạng thái đó đúng. Một trong những điểm đáng giá nhất của Suricata đó là khả năng cho phép người sử dụng có thể tự viết các luật của riêng mình hoặc tùy biến các luật có sẵn cho phù hợp với hệ thống mạng của mình. Ngoài một cơ sở dữ liệu lớn mà người sử dụng có thể download từ trang chủ của Suricata, người quản trị có thể tự phát triển các luật cho hệ thống của mình. Thay vì phải phụ thuộc vào nhà cung cấp, một cơ quan bên ngoài, hoặc phải cập nhật khi có một cuộc tấn công mới hay một phương pháp khai thác lỗ hổng mới được phát hiện. Người quản trị có thể viết riêng một luật dành cho hệ thống của mình khi nhìn thấy các lưu lượng mạng

bất thường và so sánh với bộ luật được cộng đồng phát triển. Ưu điểm của việc tự viết các luật là có thể tùy biến và cập nhật một cách cực kỳ nhanh chóng khi hệ thống mạng có sự bất thường.

Để biết cách viết một luật từ các dữ liệu của hệ thống ta cần phải hiểu cấu trúc của luật trong Suricata như thế nào. Một luật trong Suricata được chia thành hai phần đó là phần rule header và rule options. Phần rule header bao gồm: rule action, protocol, địa chỉ ip nguồn, địa chỉ ip đích, subnetmask, port nguồn, port đích. Phần options bao gồm các thông điệp cảnh báo, thông tin các phần của gói tin sẽ được kiểm tra để xác định xem hành động nào sẽ được áp dụng.

4.2. Rule Header



Cấu trúc rule (luật) trong Suricata

4.2.1. Rule Action

Phần Header sẽ chứa các thông tin xác định ai, ở đâu, cái gì của một gói tin, cũng như phải làm gì nếu tất cả các thuộc tính trong luật được hiện lên. Mục đầu tiên trong một luật đó chính là phần rule action, rule action sẽ nói cho Suricata biết phải làm gì khi thấy các gói tin phù hợp với các luật đã được quy định sẵn. Có 4 hành động mặc định trong Suricata đó là: pass (cho qua), drop (chặn gói tin), reject, alert (cảnh báo).

- Pass: nếu signature được so sánh trùng khớp và chỉ ra là pass thì Suricata sẽ thực hiện dừng quét gói tin và bỏ qua tất cả các luật phía sau đối với gói tin này.
- Drop: nếu chương trình tìm thấy một signature hợp lệ và nó chỉ ra là drop thì gói tin đó sẽ bị hủy bỏ và dừng truyền ngay lập tức, khi đó gói tin không thể đến được nơi nhận.
- Reject: là hành động bỏ qua gói tin, bỏ qua ở cả bên nhận và bên gửi. Suricata sẽ tạo ra một cảnh báo với gói tin này.
- Alert: nếu signature được so sánh là hợp lệ và có chứa một alert thì gói tin đó sẽ được xử lý giống như với một gói tin không hợp lệ. Suricata sẽ tạo ra một cảnh báo.

4.2.2. Protocol

Trường tiếp theo trong luật đó là protocol. Các giao thức mà Suricata hiện đang phân tích các hành vi bất thường đó là TLS, SSH, SMTP (tải thư điện tử qua mạng internet), IMAP (đặt sự kiểm soát email trên mail server), MSN, SMB (chia sẻ file), TCP, UDP, ICMP và IP, DNS

4.2.3. IP Address

Mục tiếp theo của phần header đó là địa chỉ IP. Các địa chỉ này dùng để kiểm tra nơi đi và nơi đến của một gói tin. Địa chỉ ip đó có thể là địa chỉ của một máy đơn hoặc cũng có thể là địa chỉ của một lớp mạng. Từ khóa “any” được sử dụng để định nghĩa một địa chỉ bất kỳ.

Một địa chỉ ip sẽ được viết dưới dạng ip_address/netmask. Điều này có nghĩa là nếu netmask là /24 thì lớp mạng đó là lớp mạng C, /16 là lớp mạng B hoặc /32 là chỉ một máy đơn. Ví dụ: địa chỉ 192.168.1.0/24 có nghĩa là một dải máy có địa chỉ IP từ 192.168.1.1- 192.168.1.255.

Trong hai địa chỉ IP trong một luật Suricata thì sẽ có một địa chỉ IP nguồn và một địa chỉ IP đích. Việc xác định đâu là địa chỉ nguồn, đâu là địa chỉ đích phụ thuộc vào "→".

Ngoài ra toán tử phủ định có thể được áp dụng cho việc định địa chỉ IP. Có nghĩa là khi sử dụng toán tử này thì Suricata sẽ bỏ qua việc kiểm tra địa chỉ của gói tin đó. Toán tử đó là "!". Ngoài ra ta có thể định nghĩa một danh sách các địa chỉ IP bằng cách viết liên tiếp chúng cách nhau bởi một dấu ",".

Ví dụ: Alert TCP any any → ![192.168.1.0/24, 172.16.0.0/16] 80 (msg: "Access")

4.2.4. Port

Port có thể được định nghĩa bằng nhiều cách. Với từ khóa "any" giống như địa chỉ IP để chỉ có thể sử dụng bất kỳ port nào. Gán một port cố định, ví dụ như gán kiểm tra ở port 80 http hoặc port 22 ssh. Ngoài ra ta cũng có thể sử dụng toán tử phủ định để bỏ qua một port nào đó hoặc liệt kê một dải các port.

Ví dụ:

Alert UDP any any → 192.168.1.0/24 1:1024 - port bất kỳ tới dãy port từ 1 - 1024.

Alert UDP any any → 192.168.1.0/24 :6000 - port bất kỳ tới dãy port nhỏ hơn 6000.

Alert UDP any any → 192.168.1.0/24 !6000:6010 - port bất kỳ tới bất kỳ port nào, bỏ qua dãy port từ 6000 – 6010.

4.2.5. Điều hướng

Toán tử hướng "→" chỉ ra đâu là hướng nguồn, đâu là hướng đích. Phần địa chỉ IP và port ở phía bên trái của toán tử được coi như là địa chỉ nguồn và port nguồn, phần bên phải được coi như địa chỉ đích và port đích. Ngoài ra

còn có toán tử “<>” Suricata sẽ xem cặp địa chỉ/port nguồn và đích là như nhau. Nghĩa là nó sẽ ghi/phân tích ở cả hai phía của cuộc hội thoại.

Ví dụ: Alert TCP !192.168.1.0/24 any <> 192.168.1.0/24 23

4.3. Rule Option

Rule options chính là trung tâm của việc phát hiện xâm nhập. Nội dung chứa các dấu hiệu để xác định một cuộc xâm nhập. Nó nằm ngay sau phần Rule Header và được bọc bởi dấu ngoặc đơn “()”. Tất cả các rule options sẽ được phân cách nhau bởi dấu chấm phẩy “;”, phần đối số sẽ được tách ra bởi dấy hai chấm “:”.

Có 4 loại rule options chính bao gồm:

- General: Tùy chọn này cung cấp thông tin về luật đó nhưng không có bất cứ ảnh hưởng nào trong quá trình phát hiện.

- Payload: Tùy chọn liên quan đến phần tải trong một gói tin.

- Non-payload: Bao gồm các tùy chọn không liên quan đến phần tải của gói tin (header).

- Post-detection: Các tùy chọn này sẽ gây ra những quy tắc cụ thể sau khi một luật đã được kích hoạt

Các thành phần khác trong Rule

4.3.1.1. General

❖ **Msg**

Msg (Message): được dùng để cho biết thêm thông tin về từng signature và các cảnh báo. Phần đầu tiên sẽ cho biết tên tập tin của signature và phần này quy ước là phải viết bằng chữ in hoa. Định dạng của msg như sau:

```
msg: “..........”;
```

❖ **Sid**

Sid (signature id): cho ta biết định danh riêng của mỗi signature. Định danh này được bắt đầu với số. Định dạng của sid như sau:

```
sid:123;
```

❖ **Rev**

Rev (revision): mỗi sid thường đi kèm với một rev. Rev đại diện cho các phiên bản của signature. Mỗi khi signature được sửa đổi thì số rev sẽ được tăng lên bởi người tạo ra. Định dạng của rev như sau:

```
rev:123;
```

❖ **Reference**

Reference: cung cấp cho ta địa chỉ đến được những nơi chứa các thông tin đầy đủ về signature. Các tham chiếu có thể xuất hiện nhiều lần trong một signature. Ví dụ về một tham chiếu như sau:

```
reference: url, www.info.nl
```

system	URL Prefix
bugtraq	http://www.securityfocus.com/bid
cve	http://cve.mitre.org/cgi-bin/cvename.cgi?name=
nessus	http://cgi.nessus.org/plugins/dump.php3?id=
arachnids	http://www.whitehats.com/info/IDS
mcafee	http://vil.nai.com/vil/dispVirus.asp?virus_k=
url	http://

Bảng các tùy chọn của Reference

❖ **Classtype**

Classtype: cung cấp thông tin về việc phân loại các lớp quy tắc và cảnh báo. Mỗi lớp bao gồm một tên ngắn gọn, một tên đầy đủ và mức độ ưu tiên.

Ví dụ:

```
Config classification: web-application-attack,Web Application Attack,1
config classification: not-suspicious,Not Suspicious Traffic,3
```

❖ **Priority**

Priority: chỉ ra mức độ ưu tiên của mỗi signature. Các giá trị ưu tiên dao động từ 1 đến 255, nhưng thường sử dụng các giá trị từ 1 -> 4. Mức ưu tiên cao nhất là 1. Những signature có mức ưu tiên cao hơn sẽ được kiểm tra trước. Định dạng như sau:

```
priority:1;
```

❖ **Metadata**

Metadata: Suricata sẽ bỏ qua những gì viết sau metadata. Định dạng như sau:

```
metadata:.....;
```

4.3.1.2. Payload

❖ **Content**

Content: thể hiện nội dung chúng ta cần viết trong signature, nội dung này được đặt giữa 2 dấu nháy kép. Nội dung là các byte dữ liệu, có 256 giá trị

khác nhau (0-255). Chúng có thể là các ký tự thường, ký tự hoa, các ký tự đặc biệt, hay là các mã hexa tương ứng với các ký tự và các mã hexa này phải được đặt giữa 2 dấu gạch dọc. Định dạng của một nội dung như sau:

```
content: ”.....”;
```

❖ **Nocase**

Nocase: được dùng để chỉnh sửa nội dung thành các chữ thường, không tạo ra sự khác biệt giữa chữ hoa và chữ thường. Nocase cần được đặt sau nội dung cần chỉnh sửa.

Ví dụ:

```
content: "abC"; nocase;
```

❖ **Depth**

Depth: sau từ khóa depth là một số, chỉ ra bao nhiêu byte từ đầu một payload cần được kiểm tra. Depth cần được đặt sau một nội dung. Ví dụ: ta có một payload : abCdefghij. Ta thực hiện kiểm tra 3 byte đầu của payload.

```
content: “abC”; depth:3;
```

❖ **Offset**

Offset: chỉ độ lệch byte trong tải trọng sẽ được kiểm tra. Ví dụ: độ lệch là 3 thì sẽ kiểm tra từ byte thứ 4 trong tải trọng.

```
content: “def”; offset:3;
```

Ví dụ:

Alert TCP 192.168.1.0/24 any -> any any (content: \"HTTP"; offset: 4; depth: 40; msg: "HTTP matched";)

❖ **Distance**

Distance: xác định khoảng cách giữa các nội dung cần kiểm tra trong payload. Khoảng cách này có thể là một số âm.

Ví dụ:

```
content: "abC"; content: "efg"; distance:1;
```

❖ **Within**

Within: được dùng cùng với distance, để chỉ độ rộng của các byte cần kiểm tra sau một nội dung với khoảng cách cho trước đó.

Ví dụ:

content:"GET"; depth:3 content:"download"; distance:10 \within:9;

Luật có nghĩa là tìm "GET" trong 3 byte đầu tiên của trường dữ liệu, di chuyển thêm 10 byte bắt đ ầu từ "GET" và tìm khớp "download". Tuy nhiên, "download" phải xuất hiện trong 9 byte tiếp theo.

❖ **Dsize**

Dsize: được dùng để tìm một payload có độ dài bất kỳ.

```
dsize:min<>max;
```

❖ **Rpc**

Rpc (Remote Procedure Call): là một ứng dụng cho phép một chương trình máy tính thực hiện một thủ tục nào đó trên một máy tính khác, thường được sử dụng cho quá trình liên lạc. Định dạng của rpc như sau:

```
rpc:<application number>, [<version number>|*], [<procedure number>|*]>;
```

❖ **Replace**

Replace được dùng để thay đổi nội dung của payload, điều chỉnh lưu lượng mạng. Việc sửa đổi nội dung của payload chỉ có thể được thực hiện đối với gói dữ liệu cá nhân. Sau khi thực hiện thay đổi nội dung xong thì Suricata sẽ thực hiện tính toán lại trường checksum.

4.3.1.3. Non-payload

a. IP

❖ **ttl**

Được sử dụng để kiểm tra về thời gian sống, tồn tại tên mạng của một địa chỉ IP cụ thể trong phần đầu của mỗi gói tin. Giá trị time-to-live (thời gian sống), xác định thời gian tối đa mà mỗi gói tin có thể được lưu thông trên hệ thống mạng. Nếu giá trị này về 0 thì gói tin sẽ bị hủy bỏ. Thời gian sống được xác định dựa trên số hop, khi đi qua mỗi hop/router thì thời gian sống sẽ bị trừ đi 1. Cơ chế này nhằm hạn chế việc gói tin lưu thông trên mạng vô thời hạn. Định dạng của một ttl như sau:

```
ttl:<number>;
```

❖ **ipopts**

Chúng ta có thể xem và tùy chỉnh các tùy chọn cho việc thiết lập các địa chỉ IP. Việc thiết lập các tùy chọn cần được thực hiện khi bắt đầu một quy tắc. Một số tùy chọn có thể sử dụng:

IP-option	Description
rr	Record Route
eol	End of List
nop	No Op
ts	Time Stamp
sec	IP Security
esec	IP Extended Security
lsrr	Loose Source Routing
ssrr	Strict Source Routing
satid	Stream Identifier
any	any IP options are set

Một số tùy chọn của Ipopts

Định dạng của một ipopts như sau:

```
ipopts: <name>;
```

❖ **sameip**

Mỗi gói tin sẽ có một địa chỉ IP nguồn và đích. Chúng ta có thể sử dụng sameip để kiểm tra xem địa chỉ IP nguồn và đích có trùng nhau hay không. Định dạng của sameip như sau:

```
sameip;
```

❖ **Ip_proto**

Được dùng để giúp ta lựa chọn giao thức. Ta có thể chọn theo tên hoặc số tương ứng với từng giao thức. Có một số giao thức phổ biến sau:

```
1   ICMP      Internet Control Message
6   TCP       Transmission Control Protocol
17  UDP       User Datagram
47  GRE       General Routing Encapsulation
50  ESP       Encap Security Payload for IPv6
51  AH        Authentication Header for Ipv6
58  IPv6-ICMP ICMP for Ipv6
```

Định dạng của ip_proto như sau:

```
ip_proto:<number/name>;
```

❖ **Id**

Được sử dụng để định danh cho các phân mảnh của gói tin được truyền đi. Khi gói tin truyền đi sẽ được phân mảnh, và các mảnh của một gói tin sẽ có ID giống nhau. Việc này giúp ích cho việc ghép lại gói tin một cách dễ dàng. Định dạng như sau:

```
id:<number>;
```

❖ **Geoip**

Cho phép xác định địa chỉ nguồn, đích để gói tin lưu thông trên mạng.

❖ **Fragbits**

Được dùng để kiểm tra các phân mảnh của gói tin. Nó bao gồm các cơ chế sau:

```
M - More Fragments
D - Do not Fragment
R - Reserved Bit
+       match on the specified bits, plus any others
*       match if any of the specified bits are set
!       match if the specified bits are not set
```

Định dạng của một Fragbits như sau:

```
fragbits:[*+!]<[MDR]>;
```

❖ **Fragoffset**

Kiểm tra sự phù hợp trên các giá trị thập phân của từng mảnh gói tin trên trường offset. Nếu muốn kiểm tra phân mảnh đầu tiên của gói tin, chúng ta cần kết hợp fragoffset 0 với các tùy chọn fragment khác. Các tùy chọn fragment như sau:

```
<       match if the value is smaller than the specified value
>       match if the value is greater than the specified value
!       match if the specified value is not present
```

Định dạng của fragoffset:

```
fragoffset:[!|<|>]<number>;
```

b. TCP

❖ **Seq**

Là một số ngẫu nhiên được tạo ra ở cả bên nhận và bên gửi gói tin để kiểm tra số thứ tự của các gói tin đến và đi. Máy khách và máy chủ sẽ tự tạo ra một số seq riêng của mình. Khi một gói tin được truyền thì số seq này sẽ tăng lên 1. Seq giúp chúng ta theo dõi được những gì diễn ra khi một dòng dữ liệu được truyền đi.

❖ **Ack**

Được sử dụng để kiểm tra xem gói tin đã được nhận bởi nơi nhận hay chưa trong giao thức kết nối TCP. Số thứ tự của ACK sẽ tăng lên tương ứng với số byte dữ liệu đã được nhận thành công.

❖ **Window**

Được sử dụng để kiểm tra kích thước của cửa sổ TCP. Kích thước cửa sổ TCP là một cơ chế dùng để kiểm soát các dòng dữ liệu. Cửa sổ được thiết lập bởi người nhận, nó chỉ ra số lượng byte có thể nhận để tránh tình trạng bên nhận bị tràn dữ liệu. Giá trị kích thước của cửa sổ có thể chạy từ 2 đến 65.535 byte.

c. ICMP

❖ **Type**

Cung cấp cho việc xác định các loại ICMP. Các thông điệp khác nhau sẽ được phân biệt bởi các tên khác nhau hay các giá trị khác nhau. Định dạng của itype như sau:

```
itype:min<>max;
itype:[<|>]<number>;
```

Type	Name	Reference
0	Echo Reply	[RFC792]
3	Destination Unreachable	[RFC792]
4	Source Quench	[RFC792]
5	Redirect	[RFC792]
6	Alternate Host Address	[JBP]
7	Unassigned	[JBP]
8	Echo	[RFC792]
9	Router Advertisement	[RFC1256]
10	Router Selection	[RFC1256]
11	Time Exceeded	[RFC792]
12	Parameter Problem	[RFC792]
13	Timestamp	[RFC792]
14	Timestamp Reply	[RFC792]
15	Information Request	[RFC792]
16	Information Reply	[RFC792]
17	Address Mask Request	[RFC950]
18	Address Mask Reply	[RFC950]
19	Reserved (for Security)	[Solo]
20-29	Reserved (for Robustness Experiment)	[ZSu]
30	Traceroute	[RFC1393]
31	Datagram Conversion Error	[RFC1475]
32	Mobile Host Redirect	[David Johnson]
37	Domain Name Request	[RFC1788]
38	Domain Name Reply	[RFC1788]
39	SKIP	[Markson]
40	Photuris	[RFC2521]

Bảng Type của ICMP Header

❖ Icode

Cho phép xác định mã của từng ICMP để làm rõ hơn cho từng gói tin ICMP. Định dạng của icode như sau:

```
icode:min<>max;
icode:[<|>]<number>;
```

❖ **Icmp_id**

Mỗi gói tin ICMP có một giá trị ID khi chúng được gửi. Tại thời điểm đó, người nhận sẽ trả lại tin nhắn với cùng một giá trị ID để người gửi sẽ nhận ra và kết nối nó đúng với yêu cầu ICMP đã gửi trước đó. Định dạng của một icmp_id như sau:

```
icmp_id:<number>;
```

❖ **Icmp_seq**

Được sử dụng để kiểm tra số thứ tự của ICMP. Định dạng của icmp_seq như sau:

```
icmp_seq:<number>;
```

d. HTTP

❖ **http_method**

Chỉ ra các phương thức được áp dụng với các request http. Các phương thức http: GET, POST, PUT, HEAD, DELETE, TRACE, OPTIONS, CONNECT và PATCH.

❖ **http_uri và http_raw_uri**

Chỉ ra đường dẫn tới nơi chứa nội dung yêu cầu.

❖ **http_header**

Chỉ ra phương thức sử dụng, địa chỉ cần truy cập tới và tình trạng kết nối.

❖ **http_cookie**

❖ **http_user_agent**

Là một phần của http_header, chỉ ra thông tin về trình duyệt của người dùng

❖ **http_client_body**

Chỉ ra các yêu cầu của máy trạm

❖ **http_stat_code**

Chỉ ra mã trạng thái của server mà máy trạm yêu cầu kết nối tới.

❖ **http_stat_msg**

Các dòng tin thông báo về tình trạng máy chủ, hay tình trạng về việc đáp ứng các yêu cầu kết nối của máy trạm.

❖ **http_server_body**

Chỉ ra nội dung đáp trả các yêu cầu từ máy trạm của máy chủ.

❖ **File_data**

Chỉ ra nội dung, đường dẫn tới file chứa dữ liệu được yêu cầu

e. Flow

❖ **Flowbits**

Gồm 2 phần, phần đầu mô tả các hành động được thực hiện, phần thứ 2 là tên của flowbit. Các hành động của flowbit:

flowbits: set, name *Được dùng để thiết lập các điều kiện/tên cho các flow.*

flowbits: isset, name *Có thể được sử dụng trong các luật để đảm bảo rằng sẽ tạo ra một cảnh báo khi các luật là phù hợp và các điều kiện sẽ được thiết lập trong flow.*

flowbits: toggle, name *Dùng để đảo ngược các thiết lập hiện tại.*

flowbits: unset, name *Được sử dụng để bỏ các thiết lập về điều kiện trong luật.*

flowbits: isnotset, name *Được sử dụng để đảm bảo rằng sẽ tạo ra một cảnh báo khi các luật là phù hợp và các điều kiện sẽ không được thiết lập trong flow.*

❖ **Flow**

Có thể được sử dụng để kết nối các thư mục chứa các flow lại với nhau. Các flow có thể được đi từ hoặc đến từ Client/Server và các flow này có thể ở trạng thái được thiết lập hoặc không. Việc kết nối các flow có thể xảy ra các trường hợp sau:

to_client *established/ stateless*

from_client *established/ stateless*

to_server *established/ stateless*

from_server *established/ stateless*

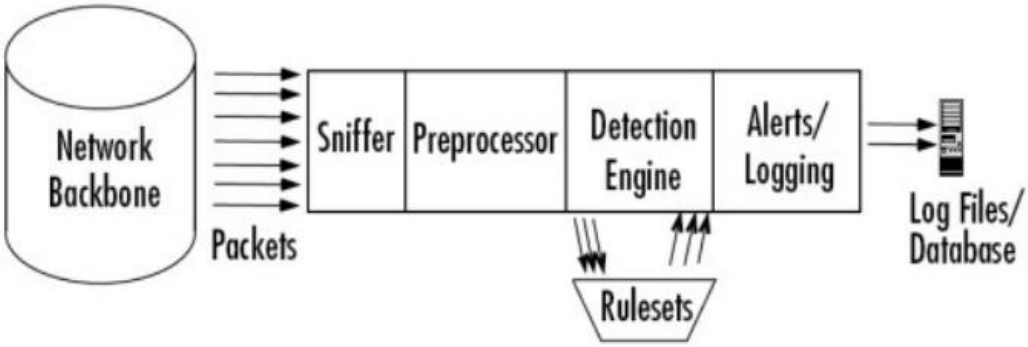
5. Kiến trúc xử lí của Suricata

5.1. Các quá trình xử lí

Suricata được phát triển dựa trên Snort nên nó vẫn giữ nguyên kiến trúc bên trong của Snort. Kiến trúc của nó có nhiều thành phần, với mỗi thành phần có một chức năng riêng

Kiến trúc của Suricata gồm 4 phần cơ bản sau:

- The Sniffer (Packet Decoder) .
- The Preprocessors.
- The Detection Engine.
- The Output: gồm hai modules:
  - Modul Alert/ Logging
  - Modul kết xuất thông tin



Kiến trúc của Suricata

5.2. Ý nghĩa của từng quá trình

a. Packet Sniffer (Decoder)

Khi Suricata hoạt động nó sẽ thực hiện lắng nghe và thu bắt tất cả các gói tin nào di chuyển qua nó.

Các gói tin sau khi bị bắt được đưa và module Sniffer, tại đây các gói tin sẽ được giải mã

b. Preprocessors

Tiếp theo gói tin sẽ được đưa vào module Preprocessor, tại đây gói tin sẽ được phân tích một cách chi tiết và đầy đủ theo các cách khác nhau

c. Detection Engine

Sau khi phân tích xong các gói tin được đưa vào module Detection. Tại đây, tùy theo việc có phát hiện được xâm nhập hay không mà gói tin có thể được lưu thông tiếp hay được đưa vào module Alert/ Logging để xử lý.

d. Thành phần cảnh báo/logging

Khi các cảnh báo được xác định module kết xuất thông tin sẽ thực hiện việc đưa cảnh báo ra theo đúng định dạng mong muốn.

Preprocessors, detection engine và alert system đều là các plug-ins. Điều này giúp cho việc chỉnh sửa hệ thống theo mong muốn của người quản trị một cách dễ dàng.

6. Ưu và nhược điểm

6.1. Ưu điểm

- Suricata sử dụng nhiều công nghệ cho việc phân tích dữ liệu như: Protocol keywords, File matching, Lua scripting …. Hơn thế, nó hỗ trợ report ra các dạng file .log và các định dạng khác hỗ trợ cho việc phân tích hay đẩy dữ liệu ra ngoài hệ thống khác.
- Cho phép thay đổi tốc độ xử lý các sự kiện hay và kiểm soát các phân vùng mạng cũng như các tính năng mở khác.
- Khả năng phát hiện các tấn công đã biết, các vi phạm chính sách, và các hành vi của mã độc là các tính năng có sẵn của Suricata tương đương

với chức năng IDS/IPS. Với khả năng phân tích gói tin trên nhiều card mạng là một ưu điểm mạnh của suricata.

- Khả năng tự động phát hiện các giao thức phổ biến như HTTP để phân tích và tìm ra các mối nguy hiểm như mã độc hay các kết nối tới máy chủ độc hại ngoài.
- Dễ dàng cấu hình: Suricata làm việc như thế nào, tập tin cấu hình ở đâu, các luật như thế nào người quản trị đều có thể biết và cấu hình theo ý mình được. Kể cả việc tạo ra các luật mới.
- Suricata là phần mềm mã nguồn mở: Sricata được phát hành dưới giấy phép GNU/GPL điều này có nghĩa là bất cứ ai cũng có thể sử dụng Suricata một cách miễn phí dù đó là doanh nghiệp hay người dùng cá nhân. Ngoài ra vì là phần mềm mã nguồn mở nên Suricata có một cộng đồng người sử dụng lớn.
- Chạy trên nhiều nền tảng khác nhau: Chạy trên các hệ điều hành nguồn mở như Linux, FreeBSD, Microsoft Windows, Mac OS X (10.5.8 and 10.6.8)…
- Luật của Suricata thường xuyên được cập nhật: Các luật của Suricata thường xuyên được bổ sung và cập nhật các hình thức xâm nhập mới. Người sử dụng có thể dễ dàng tải về từ https://rules.emergingthreats.net/open/suricata/

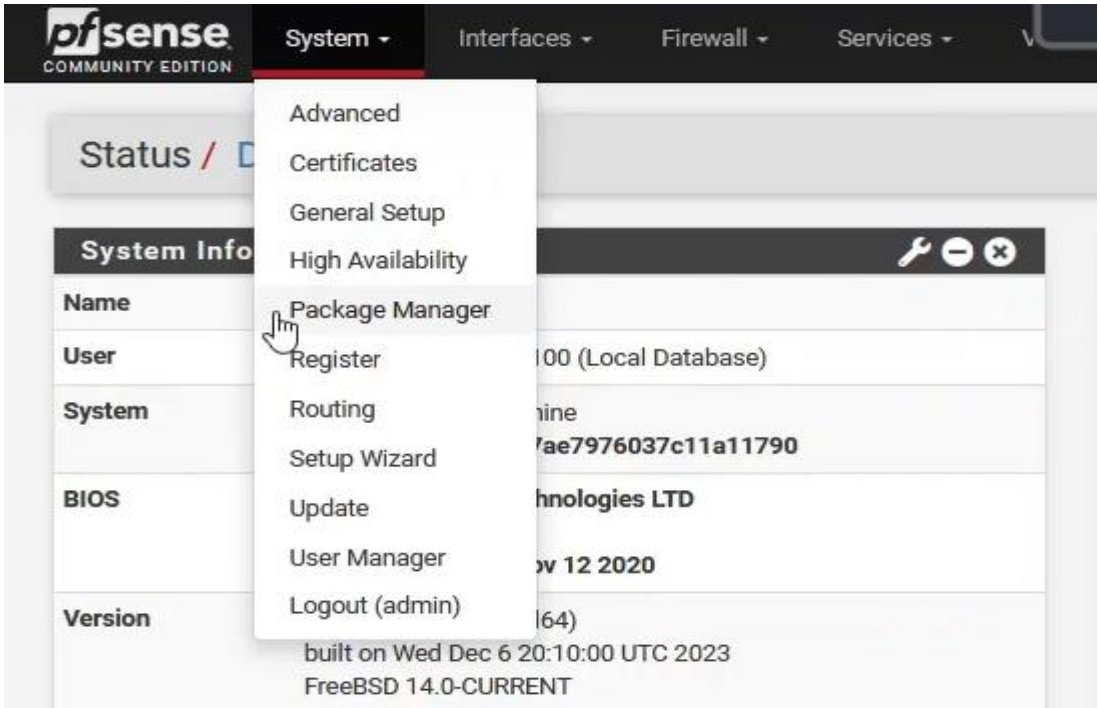
6.2. Nhược điểm

- **Tài nguyên hệ thống:** Tiêu thụ nhiều tài nguyên hệ thống, có thể ảnh hưởng đến hiệu năng của hệ thống.
- **Báo động giả:** Dễ tạo ra các báo động sai, gây lãng phí thời gian.
- **Độ trễ:** Có thể phát hiện tấn công chậm trễ.
- **Độ phức tạp cấu hình:** Cần kiến thức chuyên sâu để cấu hình.

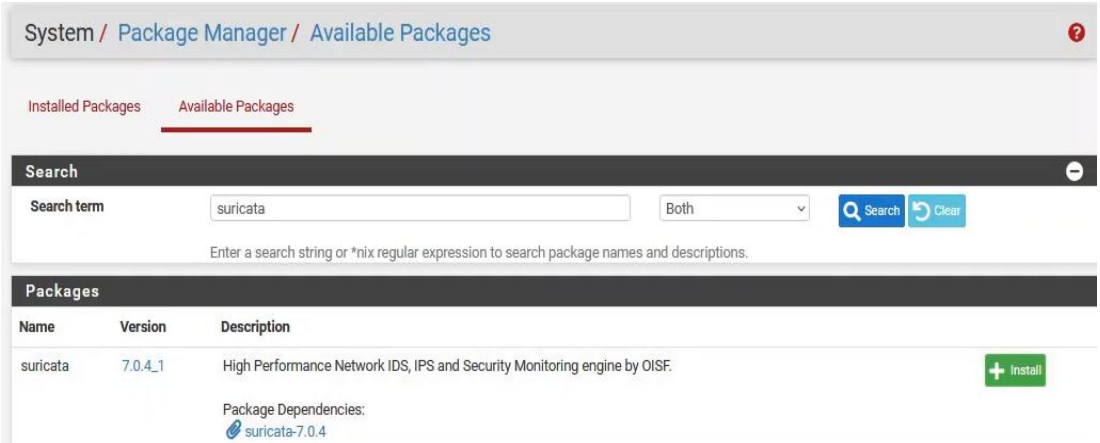
- **Khả năng mở rộng:** Khó quản lý khi mạng lớn.

7. Cài đặt Suricata trên Pfsense

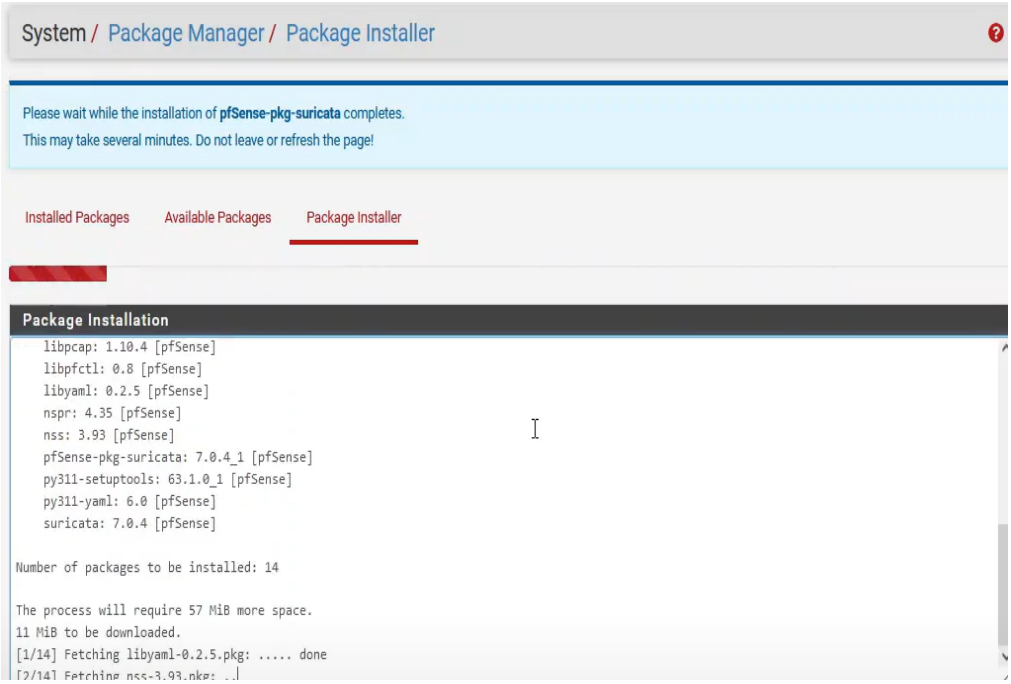
- System -> Package Manager



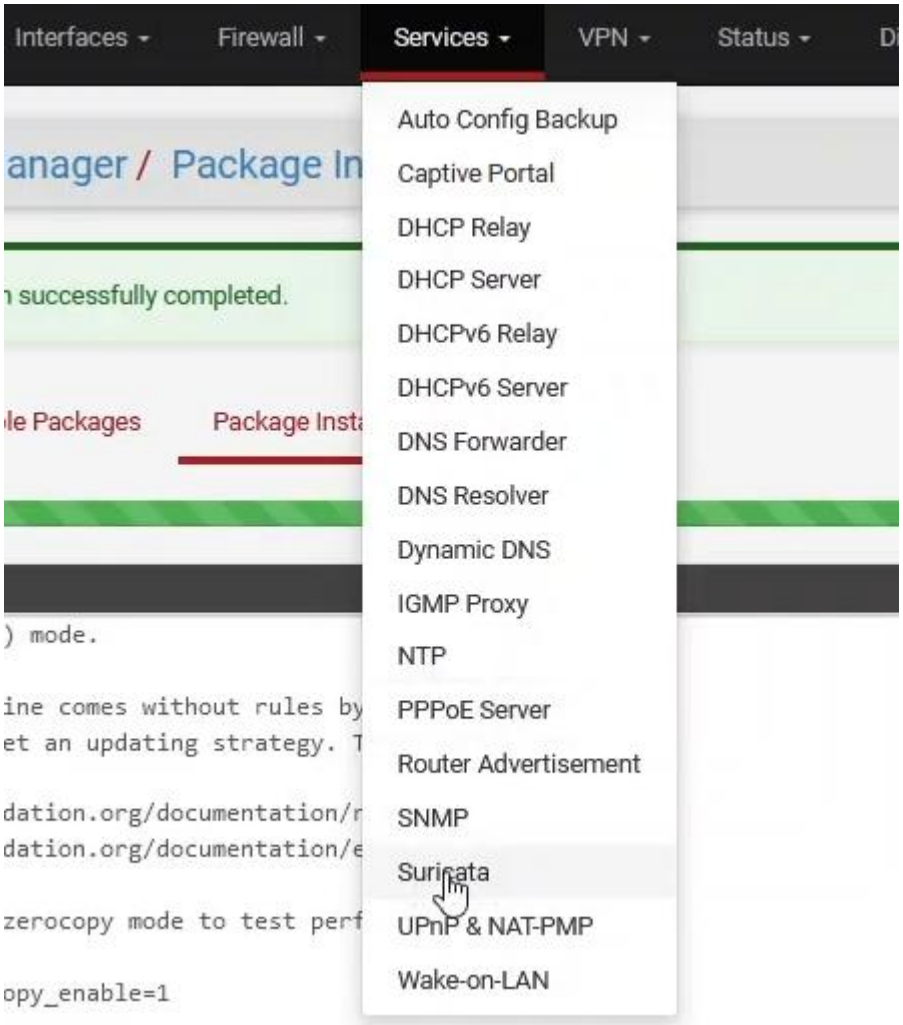
- Availble Packages -> Suricata -> Search



- Install -> Confirm -> đợi một chút

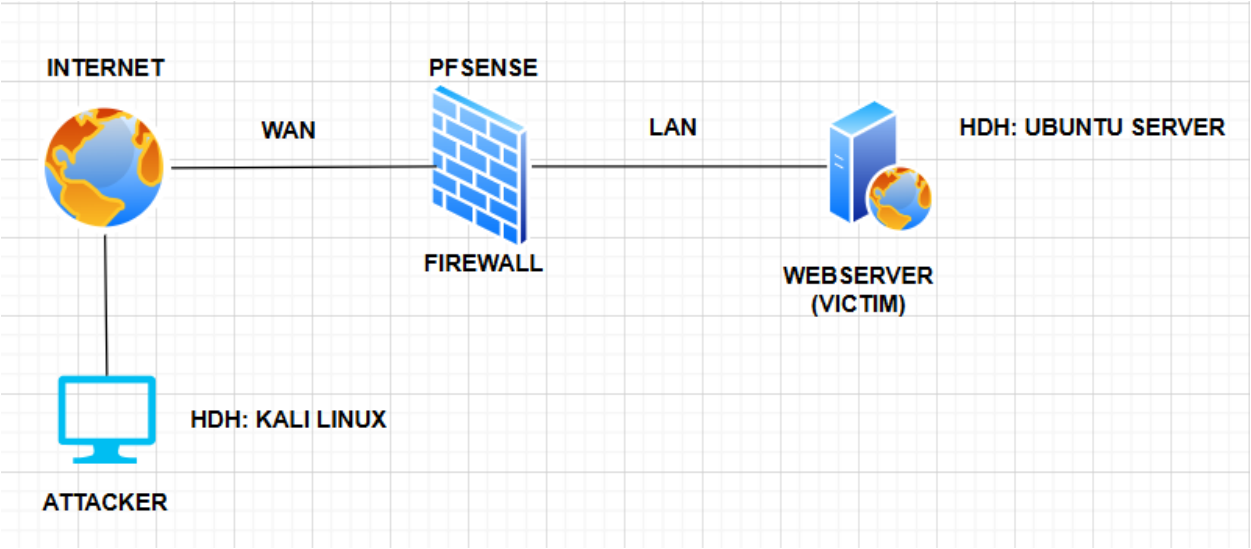


- Kiểm tra: Vào Services -> Suricata


Interfaces
Firewall
Services
VPN
Status
anager / Package In
successfully completed.
le Packages
Package Insta
) mode.
ine comes without rules by
et an updating strategy. T
dation.org/documentation/r
dation.org/documentation/e
zerocopy mode to test perf
opy_enable=1
Auto Config Backup
Captive Portal
DHCP Relay
DHCP Server
DHCPv6 Relay
DHCPv6 Server
DNS Forwarder
DNS Resolver
Dynamic DNS
IGMP Proxy
NTP
PPPoE Server
Router Advertisement
SNMP
Suricata
UPnP & NAT-PMP
Wake-on-LAN

PHẦN III. THỰC NGHIỆM – DEMO

1. Mô hình

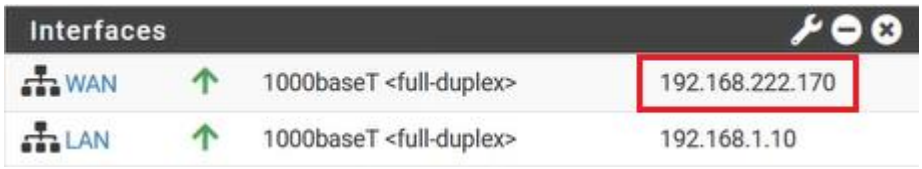


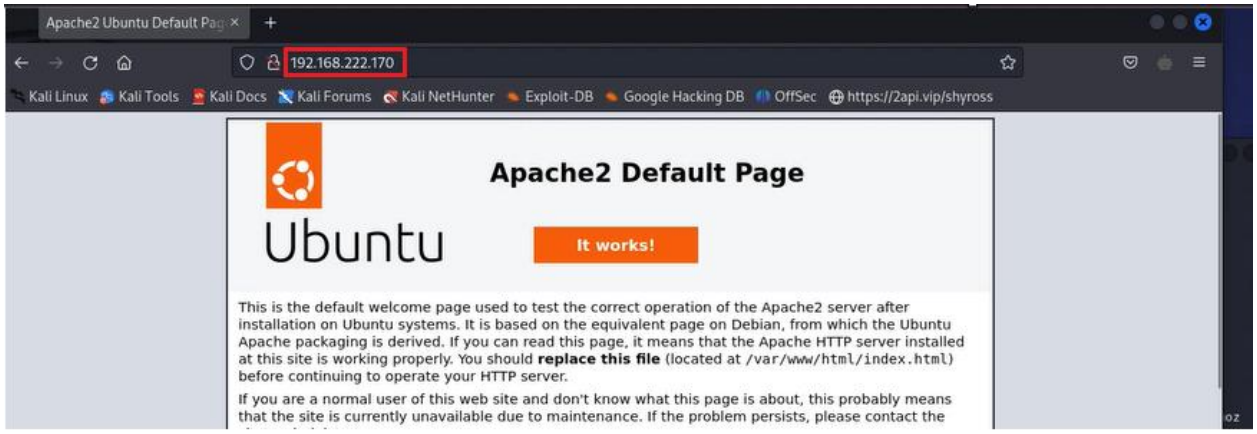
2. Công cụ thực hiện

- Vmware Workstation
- 1 máy ảo HDH Ubuntu server (Cài đặt Webserver)
- 1 máy ảo Pfsense (Cài đặt Suricata)
- 1 máy ảo HDH Kali linux

3. Thực nghiệm

Đầu tiên, ta sử dụng cơ chế NAT của Pfsense để có thể truy cập bằng IP WAN của Pfsense



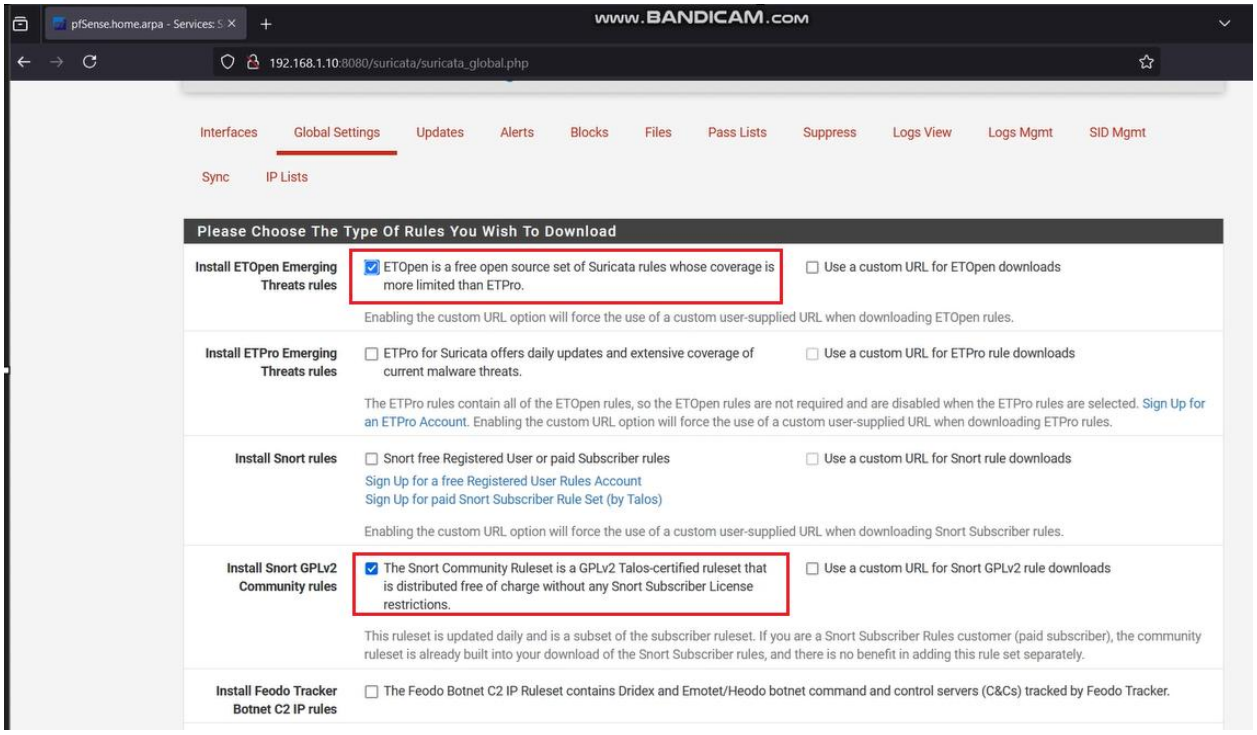


3.1 Kịch bản 1

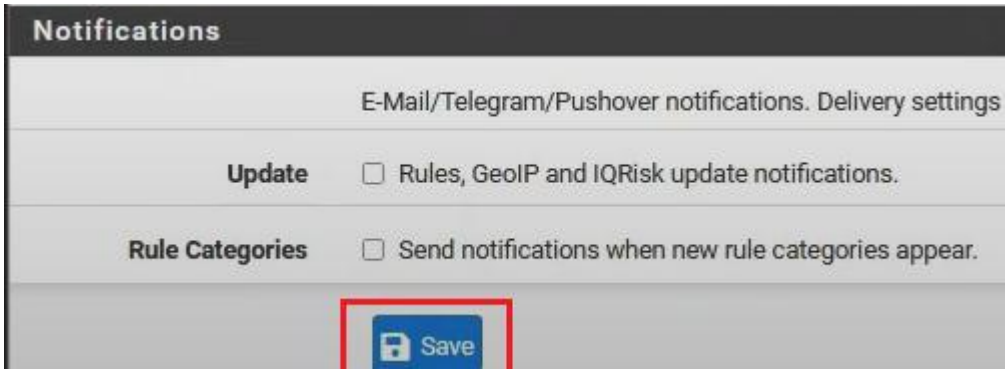
Trong kịch bản này, ta sẽ sử dụng sử dụng 1 số bộ Rule có sẵn trên Suricata

B1: Services -> Suricata -> Global Settings

Chọn ETOpen Emerging và Snort GPLv2



Lướt xuống và chọn Save



Giới thiệu:

- ETOpen là một tập hợp các quy tắc mã nguồn mở miễn phí được sử dụng trong các hệ thống phát hiện và ngăn chặn xâm nhập mạng (IDS/IPS), như Suricata hoặc Snort. Bộ quy tắc này được phát triển và duy trì bởi Emerging Threats, một tổ chức nổi tiếng về việc cung cấp các quy tắc an ninh mạng để phát hiện các mối đe dọa.
- ETOpen được sử dụng rộng rãi trong cộng đồng an ninh mạng vì nó cung cấp một cách hiệu quả để phát hiện các hành vi xâm nhập, tấn công mạng, phần mềm độc hại, botnet và các mối đe dọa khác mà không cần phải mua bộ quy tắc trả phí. Tuy nhiên, phạm vi của ETOpen không rộng và cập nhật nhanh như ETPro (phiên bản trả phí với độ bao phủ cao hơn và khả năng cập nhật nhanh chóng).

Các loại quy tắc chính trong ETOpen:

Quy tắc phát hiện tấn công mạng (Network Attack Detection):

Các quy tắc này nhằm phát hiện các hành vi tấn công mạng phổ biến như tấn công từ chối dịch vụ (DDoS), tấn công qua SQL injection, brute force, và nhiều loại tấn công khác.

- Quy tắc phát hiện phần mềm độc hại (Malware Detection):

Các quy tắc này nhận diện các mẫu lưu lượng mạng tương ứng với hành vi của phần mềm độc hại, ví dụ như ransomware, trojan, hoặc các cuộc tấn công từ các botnet.

- Quy tắc phát hiện lỗ hổng (Vulnerability Detection):

Quy tắc này được thiết kế để phát hiện các lưu lượng mạng khai thác lỗ hổng trong phần mềm, từ đó giúp chặn đứng các cuộc tấn công khai thác (exploitation attacks).

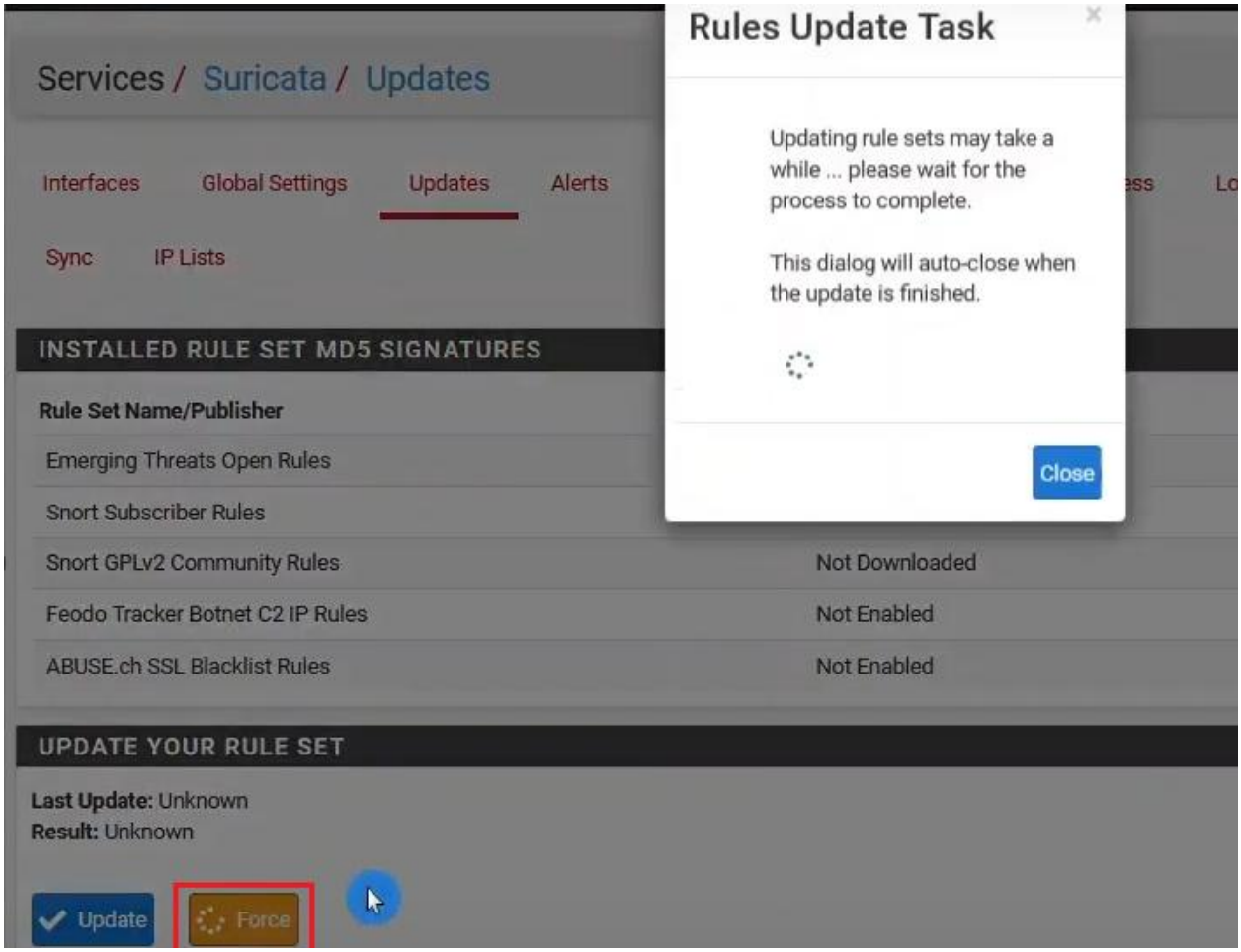
- Quy tắc phát hiện các kết nối mạng nguy hiểm (Threat Intelligence Feeds):

Chúng giúp phát hiện các kết nối đến các IP hoặc domain đã được biết là nguy hiểm, như những hệ thống đang kiểm soát botnet, máy chủ C2 (Command & Control), hoặc các máy chủ phát tán phần mềm độc hại.

Snort Community Ruleset là một tập hợp các quy tắc bảo mật nguồn mở được cung cấp miễn phí theo giấy phép GPLv2. Đây là những quy tắc đã được Talos chứng nhận, nghĩa là chúng được kiểm tra và phê duyệt để phát hiện các hoạt động xâm nhập và mối đe dọa mạng. Talos là đội ngũ chuyên gia bảo mật hàng đầu, và quy tắc của họ thường được sử dụng trong các công cụ phát hiện xâm nhập mạng.

Việc sử dụng cả ETOpen và Snort Community Ruleset có thể giúp bạn đa dạng hóa khả năng bảo vệ mạng, vì chúng đến từ hai nguồn khác nhau và có thể bổ sung cho nhau trong việc phát hiện các mối đe dọa.

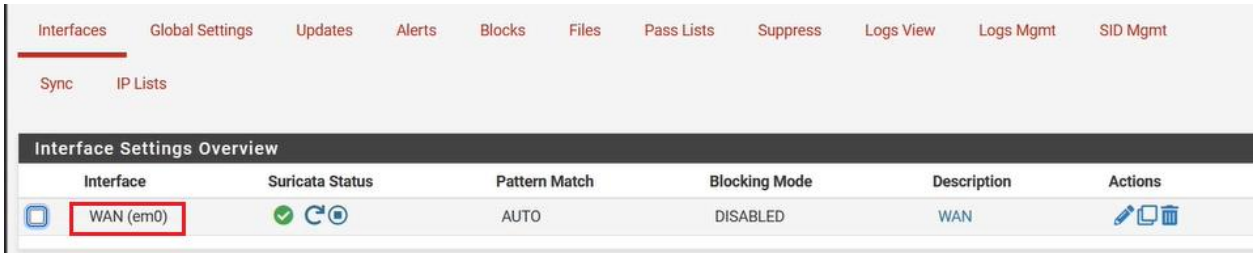
B2: Qua tab Updates -> Forces -> Đợi 1 lát

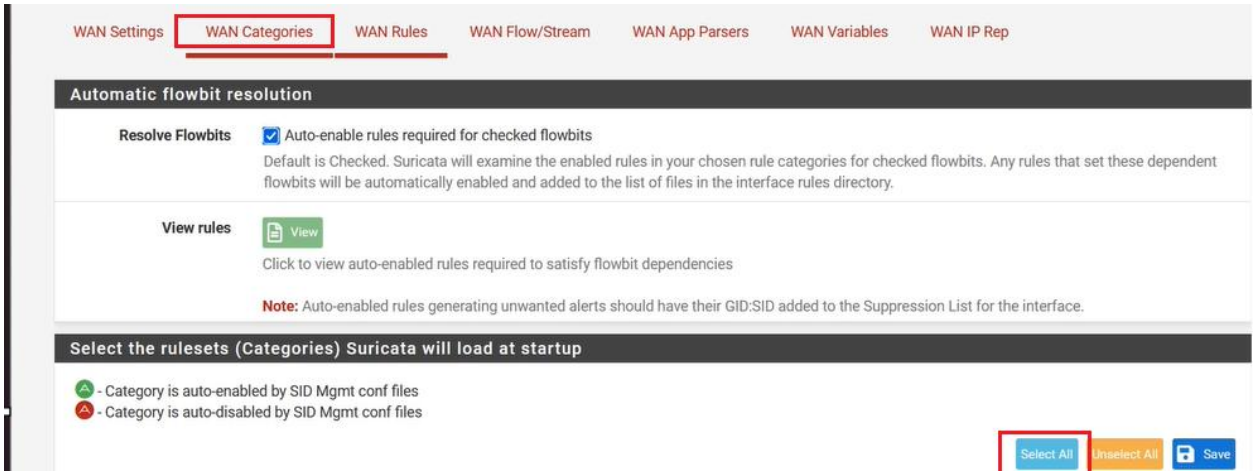


B3: Chọn Rule cho Interface

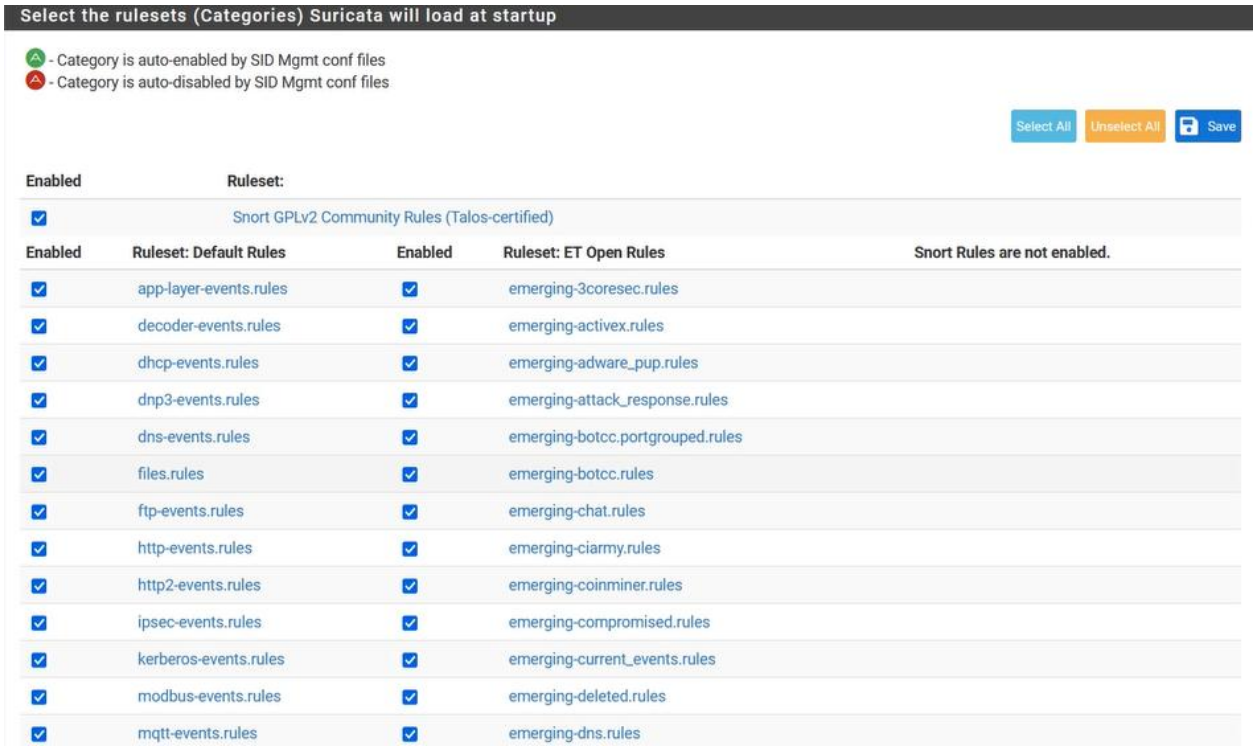
Tại tab Interface -> chọn WAN

Tại WAN Categories -> Select All -> Save





Đây là những Rule phát hiện mối đe dọa từ nhiều nguồn khác nhau mà ta đã tải từ ETOpen Emerging Snort GPLv2



Chọn Save.

B4: Ta sử dụng máy Attacker (Kali Linux) để tấn công vào Webserver

Đầu tiên ta sẽ sử dụng lệnh

Nmap -sS -p -n -Pn –min-rate=9362 192.168.222.170

Nmap sẽ gửi một gói SYN đến cổng mục tiêu, giống như khi bắt đầu thiết lập một kết nối TCP, Tùy chọn này yêu cầu Nmap quét tất cả các cổng từ 1 đến 65535 thay vì chỉ quét các cổng mặc định, Tùy chọn này yêu cầu Nmap gửi ít nhất 9362 gói tin mỗi giây.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -p- -n -Pn --min-rate=9362 192.168.222.170
[sudo] password for kali:
Starting Nmap 7.93 ( https://nmap.org ) at 2024-09-04 12:31 EDT
Nmap scan report for 192.168.222.170
Host is up (0.0022s latency).
Not shown: 65534 filtered tcp ports (no-response)
PORT   STATE SERVICE
80/tcp open  http
MAC Address: 00:0C:29:FE:04:B8 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 14.27 seconds
```

Sau đó ta qua Pfsense kiểm tra

Services -> Suricata -> Alert

Alert Log View Filter

Last 250 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
09/03/2024 17:20:32	⚠	2	TCP	Attempted Information Leak	192.168.222.156	60069	192.168.222.170	5801	1:2002910	ET SCAN Potential VNC Scan 5800-5820
09/03/2024 17:20:31	⚠	2	TCP	Potentially Bad Traffic	192.168.222.156	60071	192.168.222.170	5432	1:2010939	ET SCAN Suspicious inbound to PostgreSQL port 5432
09/03/2024 17:20:31	⚠	2	TCP	Potentially Bad Traffic	192.168.222.156	60069	192.168.222.170	5432	1:2010939	ET SCAN Suspicious inbound to PostgreSQL port 5432
09/03/2024 17:20:30	⚠	2	TCP	Attempted Information Leak	192.168.222.156	60069	192.168.222.170	5920	1:2002911	ET SCAN Potential VNC Scan 5900-5920
09/03/2024 17:20:30	⚠	2	TCP	Potentially Bad Traffic	192.168.222.156	60071	192.168.222.170	3306	1:2010937	ET SCAN Suspicious inbound to mySQL port 3306
09/03/2024 17:20:29	⚠	2	TCP	Potentially Bad Traffic	192.168.222.156	60069	192.168.222.170	3306	1:2010937	ET SCAN Suspicious inbound to mySQL port 3306

Ta thấy, Suricata đã cảnh báo

Potential VNC Scan: Suricata phát hiện có một hoạt động tiềm ẩn quét cổng VNC trong khoảng cổng từ 5800 đến 5820.

Suspicious Inbound to PostgreSQL/MySQL: Suricata nhận diện lưu lượng truy cập đáng ngờ đến các cổng dịch vụ PostgreSQL (5432) và MySQL (3306).

,...

B5: Tiếp theo, ta thử sử dụng Nikto

Nikto -h 192.168.222.170

Lệnh này sẽ: Quét web server: Kiểm tra máy chủ web được cung cấp qua địa chỉ IP để phát hiện các vấn đề bảo mật.

Kiểm tra các lỗ hổng thông thường: Nikto sẽ tìm kiếm các lỗ hổng phổ biến như cấu hình máy chủ không an toàn, các tệp tin nhạy cảm có thể bị lộ, lỗi phần mềm đã biết, v.v.

```
┌──(kali㉿kali)-[~]
└─$ sudo nikto -h 192.168.222.170
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.222.170
+ Target Hostname:    192.168.222.170
+ Target Port:        80
+ Start Time:         2024-09-04 12:34:09 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.4.58 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.moz
illa.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render
 the content of the site in a different fashion to the MIME type. See: https://www.netsparke
r.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

Ta qua Pfsense kiểm tra

Suricata đã phát hiện và cảnh báo

Last 250 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
09/03/2024 17:21:06		3	TCP	Generic Protocol Command Decode	192.168.222.156	51278	192.168.222.170	80	1:2260002	SURICATA Applayer Detect protocol only one direction
09/03/2024 17:21:06		2	TCP	Potentially Bad Traffic	192.168.222.156	51270	192.168.222.170	80	1:2010766	ET INFO Proxy TRACE Request - inbound
09/03/2024 17:21:06		2	TCP	Potentially Bad Traffic	192.168.222.156	51270	192.168.222.170	80	1:2010766	ET INFO Proxy TRACE Request - inbound
09/03/2024 17:21:06		3	TCP	Generic Protocol Command Decode	192.168.222.156	51266	192.168.222.170	80	1:2221028	SURICATA HTTP Host header invalid
09/03/2024 17:21:06		3	TCP	Generic Protocol Command Decode	192.168.222.156	51262	192.168.222.170	80	1:2260002	SURICATA Applayer Detect protocol only one direction
09/03/2024 17:21:06		2	TCP	Attempted Information Leak	192.168.222.156	51240	192.168.222.170	80	1:2009485	ET WEB_SERVER /etc/shadow Detected in URI
09/03/2024 17:21:06		1	TCP	Attempted Administrator Privilege Gain	192.168.222.156	51240	192.168.222.170	80	1:31978	OS-OTHER Bash CGI environment variable injection attempt
09/03/2024 17:21:06		1	TCP	Attempted Administrator Privilege Gain	192.168.222.156	51240	192.168.222.170	80	1:31978	OS-OTHER Bash CGI environment variable injection attempt

SURICATA AppLayer Detect protocol only one direction: Suricata phát hiện ra chỉ có một chiều của một giao thức ứng dụng được gửi, điều này có thể cho thấy lưu lượng mạng không hoàn chỉnh hoặc bị gián đoạn.

ET INFO Proxy TRACE Request - inbound: Suricata phát hiện một yêu cầu TRACE Proxy, thường được sử dụng trong việc tìm hiểu thông tin về máy chủ từ xa, có thể liên quan đến các hoạt động thăm dò hoặc tấn công.

SURICATA HTTP Host header invalid: Phát hiện tiêu đề HTTP Host không hợp lệ, có thể là dấu hiệu của tấn công tiêm nhiễm HTTP hoặc cấu hình sai.

ET WEB_SERVER /etc/shadow Detected in URI: Phát hiện một URI chứa tham chiếu đến /etc/shadow, có thể liên quan đến một cuộc tấn công thử lấy cắp tệp mật khẩu trên hệ thống Linux/Unix.

OS-OTHER Bash CGI environment variable injection attempt: Cảnh báo về một nỗ lực tiêm nhiễm biến môi trường trong CGI Bash, có thể liên quan đến lỗ hổng Shellshock.

Generic Protocol Command Decode: Suricata gặp phải một giao thức không được nhận diện cụ thể, có thể liên quan đến việc phân tích lỗi hoặc các giao thức phi chuẩn.

Potentially Bad Traffic: Lưu lượng mạng có khả năng gây hại.

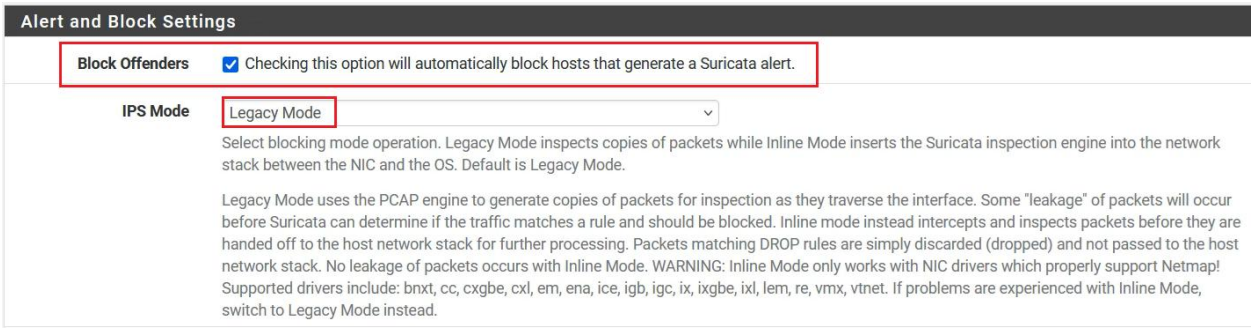
Attempted Information Leak: Cố gắng rò rỉ thông tin.

Attempted Administrator Privilege Gain: Cố gắng leo thang quyền hạn của quản trị viên.

Bước 6: Ta sẽ thử sử dụng tính năng chặn có sẵn trên giao diện của IPS để chặn các IP có mục đích tấn công, thăm dò.

Chọn Interface và bật Block Offenders

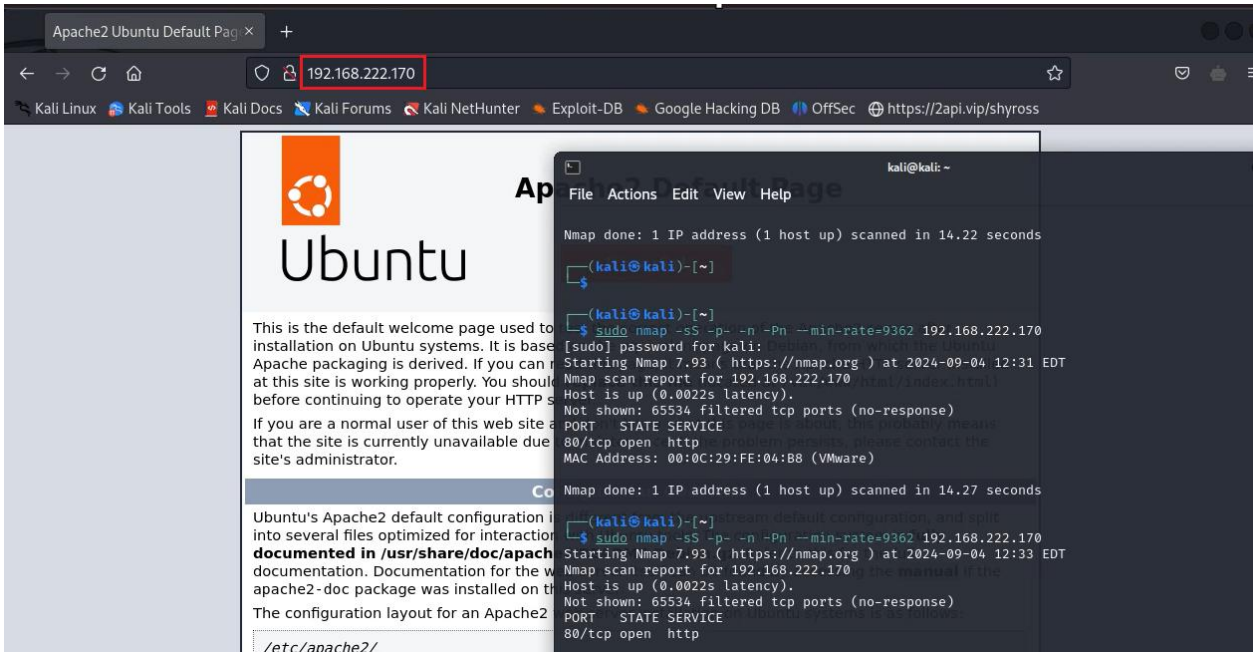
Chọn Legacy Mode và Save



Thử tấn công lại bằng lệnh Nikto

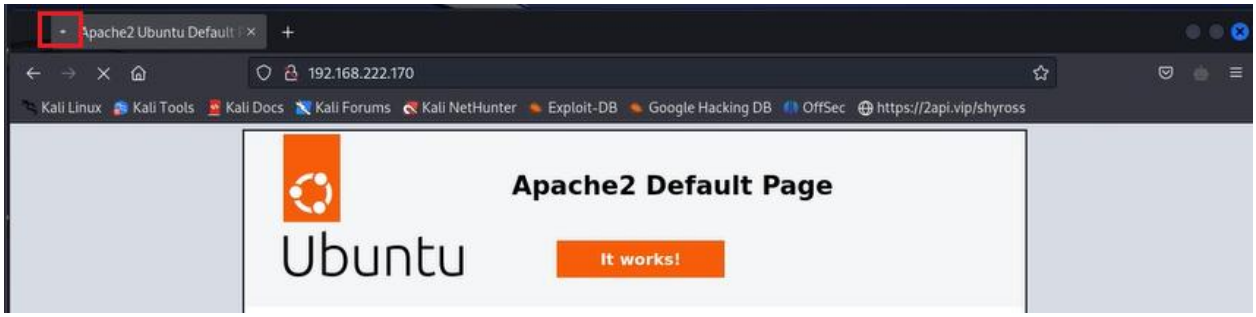
```
┌──(kali㉿kali)-[~]
└─$ sudo nikto -h 192.168.222.170
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.222.170
+ Target Hostname:    192.168.222.170
+ Target Port:        80
+ Start Time:         2024-09-04 12:34:09 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.4.58 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.moz
illa.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render
 the content of the site in a different fashion to the MIME type. See: https://www.netsparke
r.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 29af, size: 6203f467
fb78b, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, HEAD, GET, POST .
^C
```

Ta có thể thấy lúc này máy Attackers vẫn còn truy cập được Webserver, nhưng sau vài giây thì sẽ không truy cập được nữa, đây cũng là điểm yếu của Suricata, tiến trình xử lí của Suricata bị 1 độ trễ nhỏ so với thời gian thực

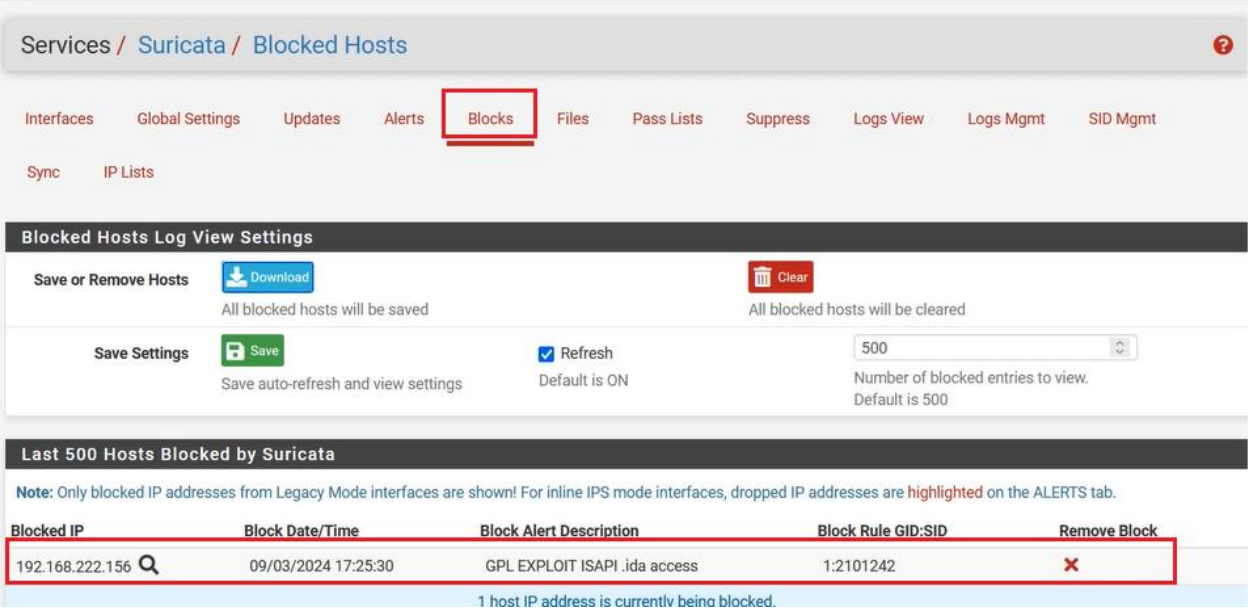


Sau vài giây thì không thể truy cập được nữa

Webserver sẽ không phản hồi và tiếp tục xoay vòng



Xem danh sách bị chặn trong Tab Block

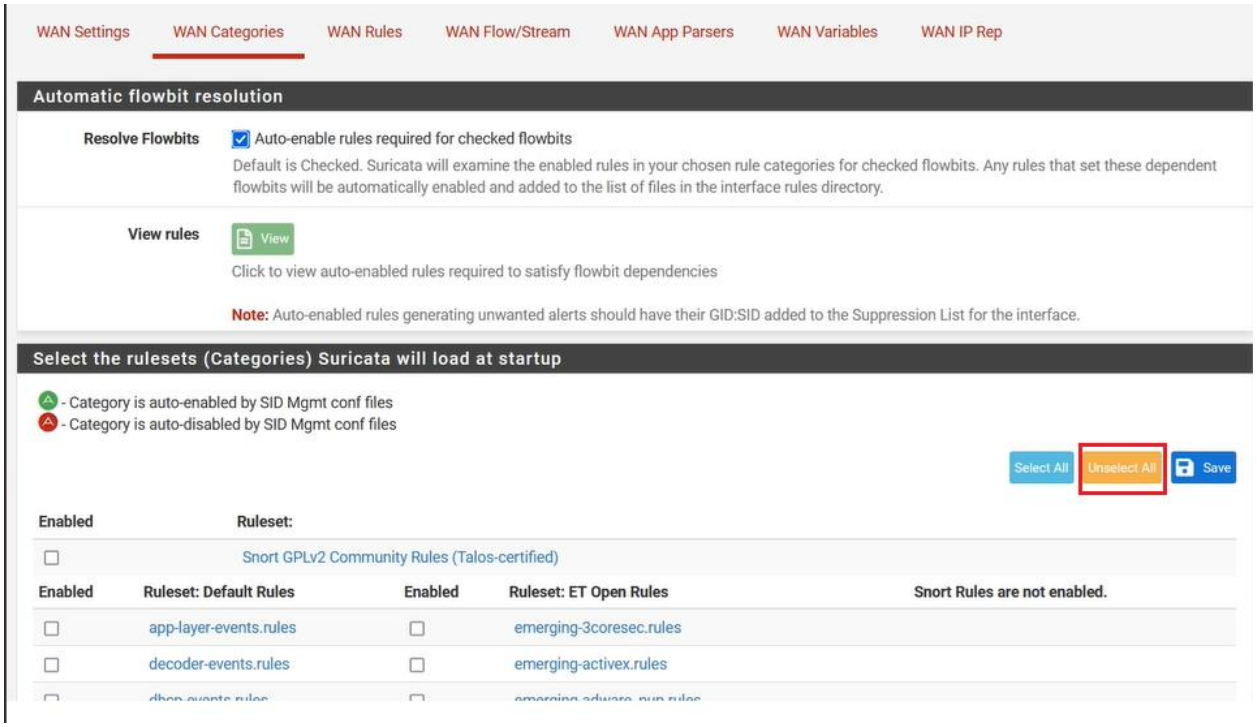


3.2Kịch bản 2

Ta sẽ sử dụng Rule custom (Rule tự viết).

B1: WAN -> Interfaces -> Wancategories -> Unselect All -> Save.

Hành động này sẽ bỏ kích hoạt tất cả các Rule sẵn có.



B2: WAN Rules -> Custom.rules -> Save.

alert tcp any any -> any [21,22,23,25,53,80,88,110,135,137,138,139,143,161,389,443,445,465,514,587,636,853,993,995,1194,1433,1720,3306,3389,8080,8443,11211,27017,51820] (msg:"POSSBL PORT SCAN (NMAP -sS)"; flow:to_server,stateless; flags:S; window:1024; tcp.mss:1460; threshold:type threshold, track by_src, count 20, seconds 70; classtype:attempted-recon; sid:3400001; priority:2; rev:1;)

Giải thích:

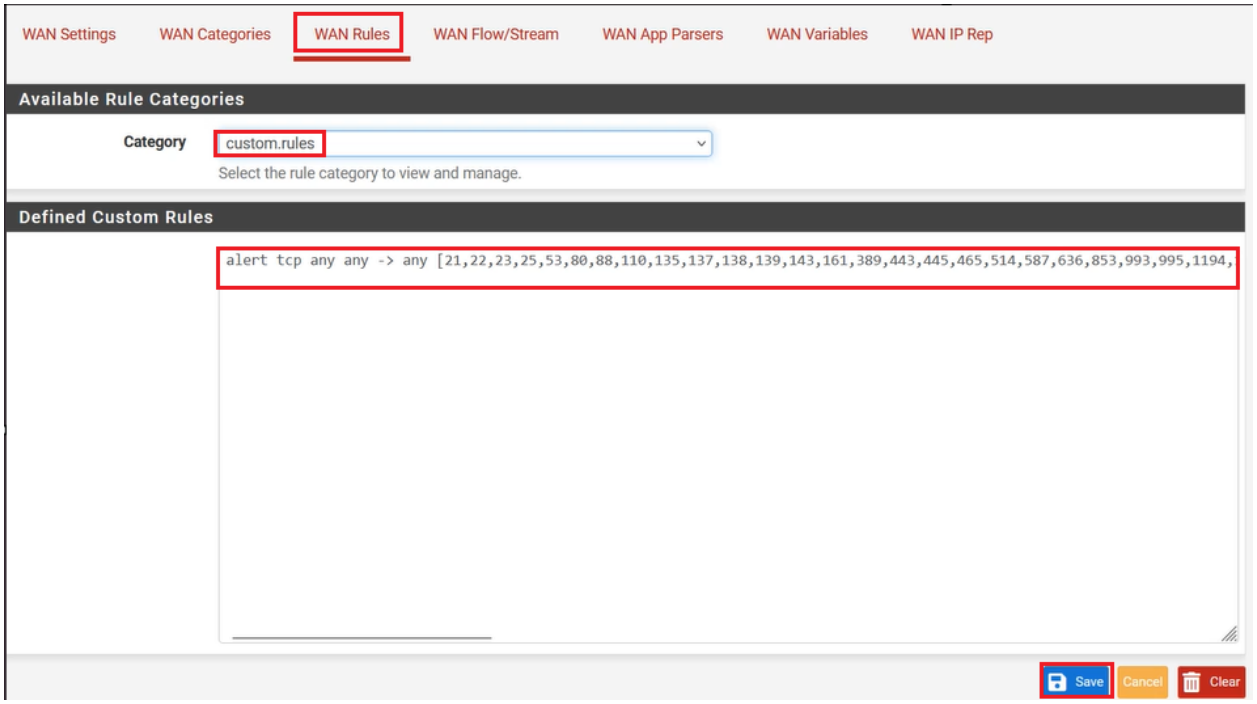
tcp any any -> any [21,22,...,51820]:

tcp: Rule này áp dụng cho các gói tin TCP.

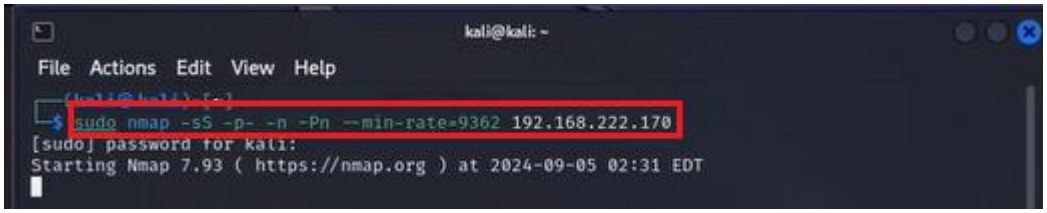
any any: Áp dụng cho mọi địa chỉ IP và mọi cổng nguồn (src IP:port).

any [21,22,...,51820]: Rule này kiểm tra các gói tin đi đến các địa chỉ IP bất kỳ, nhưng chỉ trên các cổng đích được liệt kê (như cổng 21 (FTP), 22 (SSH), 80 (HTTP), 443 (HTTPS), 3306 (MySQL), 3389 (RDP),...).

Rule này được viết để phát hiện một cuộc quét cổng (port scan) sử dụng phương pháp quét SYN của Nmap (-sS). Nó tìm kiếm các gói SYN được gửi đến các cổng thường được sử dụng trên máy chủ (như 80, 443, 3389, v.v.) từ một địa chỉ IP nguồn. Nếu có ít nhất 20 gói SYN từ cùng một địa chỉ IP trong vòng 70 giây, hệ thống sẽ tạo cảnh báo rằng có thể đang diễn ra một cuộc quét cổng Nmap.



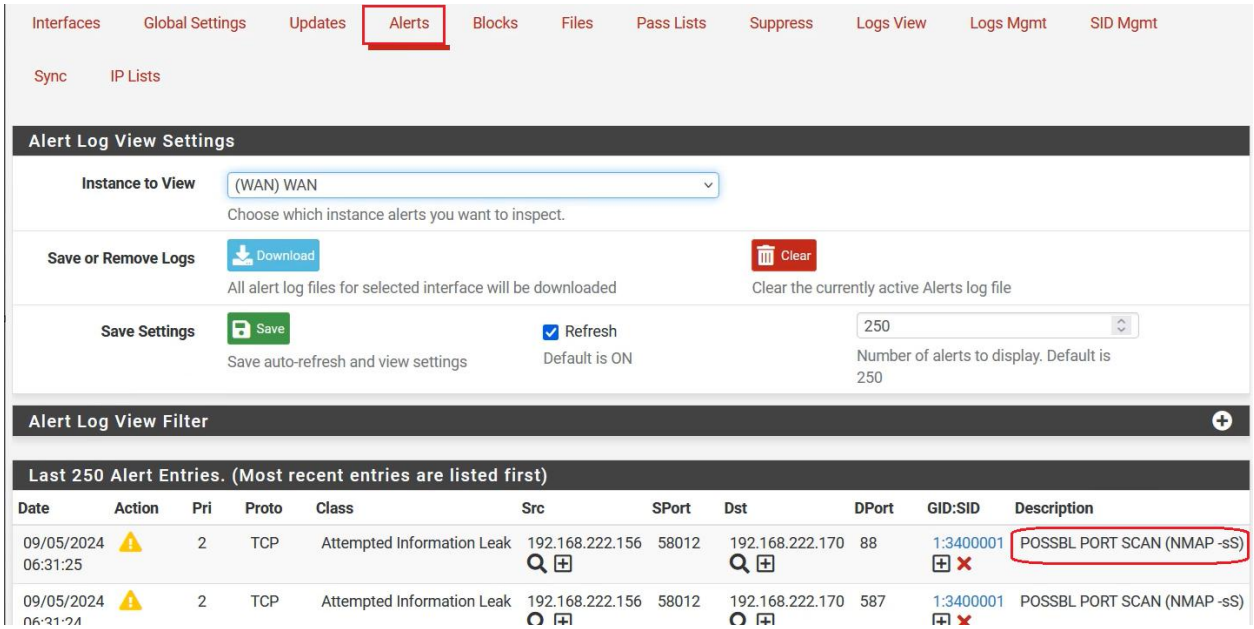
B3: Qua máy Kali thử thực hiện lại Nmap



Vào mục Alert

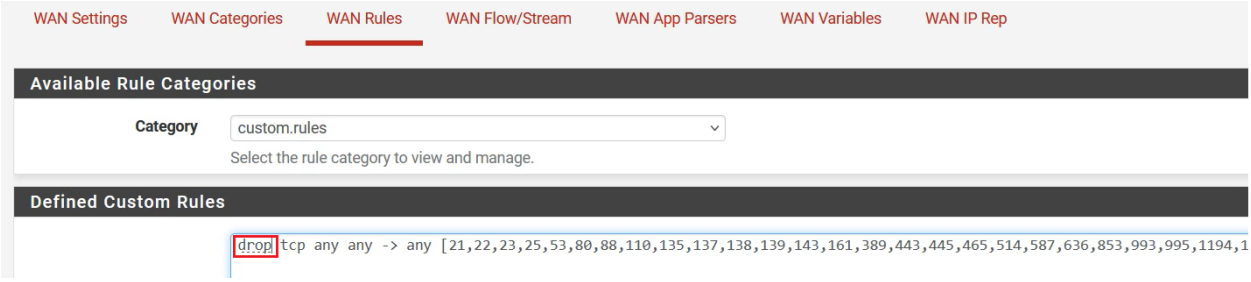
Ta thấy Suricata đã cảnh báo theo Message đã được viết trong Rule custom

➔ Rule đã được kích hoạt.



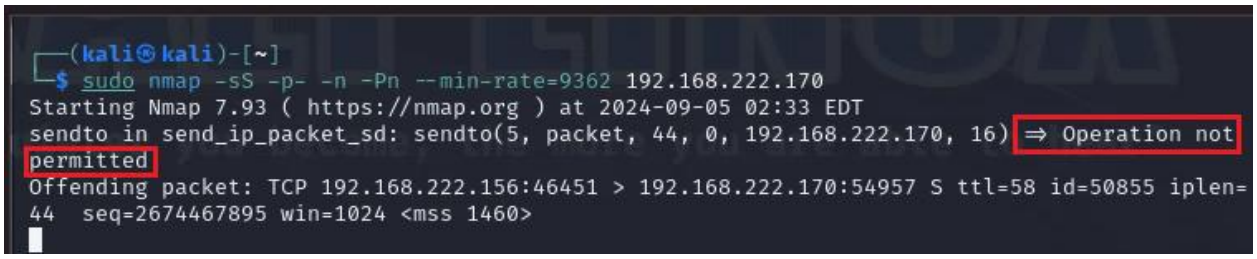
B4: Ta thử chặn IP máy Kali

Thay Alert thành Drop -> Save

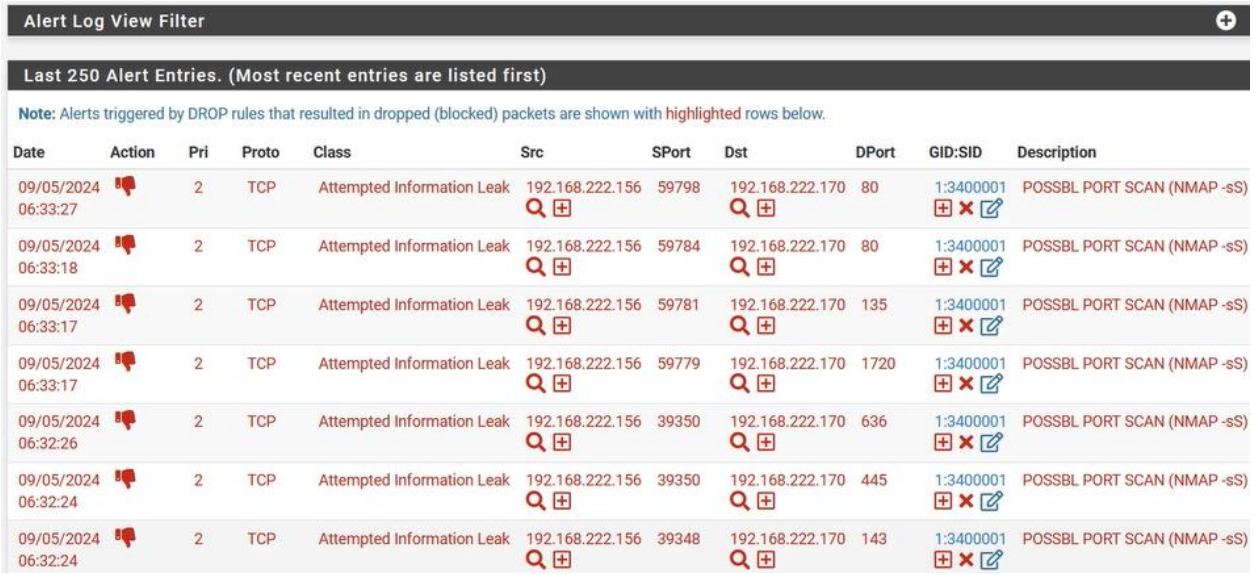


B5: Thử Nmap lại

Kết quả



Kiêm tra Alert của Suricata .



Alert Log View Filter

Last 250 Alert Entries. (Most recent entries are listed first)

Note: Alerts triggered by DROP rules that resulted in dropped (blocked) packets are shown with highlighted rows below.

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
09/05/2024 06:33:27		2	TCP	Attempted Information Leak	192.168.222.156	59798	192.168.222.170	80	1:3400001	POSSBL PORT SCAN (NMAP -sS)
09/05/2024 06:33:18		2	TCP	Attempted Information Leak	192.168.222.156	59784	192.168.222.170	80	1:3400001	POSSBL PORT SCAN (NMAP -sS)
09/05/2024 06:33:17		2	TCP	Attempted Information Leak	192.168.222.156	59781	192.168.222.170	135	1:3400001	POSSBL PORT SCAN (NMAP -sS)
09/05/2024 06:33:17		2	TCP	Attempted Information Leak	192.168.222.156	59779	192.168.222.170	1720	1:3400001	POSSBL PORT SCAN (NMAP -sS)
09/05/2024 06:32:26		2	TCP	Attempted Information Leak	192.168.222.156	39350	192.168.222.170	636	1:3400001	POSSBL PORT SCAN (NMAP -sS)
09/05/2024 06:32:24		2	TCP	Attempted Information Leak	192.168.222.156	39350	192.168.222.170	445	1:3400001	POSSBL PORT SCAN (NMAP -sS)
09/05/2024 06:32:24		2	TCP	Attempted Information Leak	192.168.222.156	39348	192.168.222.170	143	1:3400001	POSSBL PORT SCAN (NMAP -sS)

PHẦN IV. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

1. Kết luận

- Việc cài đặt và cấu hình Suricata trên pfSense đã chứng minh được vai trò quan trọng của hệ thống này trong việc bảo vệ mạng nội bộ khỏi các mối đe dọa an ninh mạng hiện đại. Suricata không chỉ cung cấp khả năng phát hiện và ngăn chặn các cuộc tấn công mạng mà còn tích hợp tốt với

pfSense, cho phép các quản trị viên mạng dễ dàng triển khai và quản lý một hệ thống bảo mật mạnh mẽ, linh hoạt. Tổng thể, Suricata trên pfSense là một giải pháp an ninh mạng hiệu quả và dễ sử dụng cho các doanh nghiệp vừa và nhỏ.

- Ưu điểm:
    - Dễ dàng đặt các Rule bảo vệ server
    - Linh hoạt trong việc áp dụng các rule từ Snort
    - Cho phép người dùng có thể tự tạo rule riêng
    - Cấu hình nhanh chóng.
    - Có nhiều phiên bản nhiều hệ điều hành khác nhau
    - Có hỗ trợ giao diện đồ họa Scirius

- Nhược điểm:
    - Điểm yếu duy nhất của Suricata là do phát triển sau Snort nên độ phổ biến còn hạn chế.

2. Hướng phát triển

✓ Do việc Microsoft tuyên bố ngừng hỗ trợ và phát triển tường lửa ISA, rất nhiều doanh nghiệp đã phải sử dụng để nhiều loại Tường lửa thế hệ mới – trong đó có Suricata.

✓ Tích hợp Suricata trên Pfsense và áp dụng các hệ thống rule chặt chẽ hơn nhờ PulledPork.

- ✓ Liên kết với Kibana và Elasticsearch, kèm theo Scirius để bất cứ ai cũng có thể dễ dàng dùng nhờ vào các tập rule có sẵn và được cập nhật liên tục tại http://rules.emergingthreats.net/open/suricata/
- ✓ **Tích hợp Suricata với Telegram** để tự động gửi cảnh báo về các sự kiện xâm nhập hoặc quét cổng, giúp quản trị viên có thể phản ứng nhanh hơn mà không cần luôn luôn theo dõi bảng điều khiển của hệ thống.
  - **Thông báo tức thời**: Telegram có thể gửi cảnh báo theo thời gian thực, giúp quản trị viên nhận thông báo trên điện thoại, máy tính hoặc thiết bị di động mọi lúc, mọi nơi.
  - **Độ linh hoạt cao**: Dễ dàng cấu hình bot Telegram để nhận cảnh báo từ các sự kiện cụ thể (ví dụ: tấn công DoS, quét cổng Nmap, v.v.).
  - **Tương thích với hệ thống hiện tại**: Telegram có API mở, dễ dàng tích hợp với các công cụ như Kibana, Elasticsearch, và Scirius thông qua các script hoặc plugin.

TÀI LIỆU THAM KHẢO

[1] http://www.openinfosecfoundation.org/index.php/download-suricata

[2] Suricata 2.0beta2 as IPS on Ubuntu 12.04 (taosecurity.blogspot.com)

[3] Suricata User Guide — Suricata 8.0.0-dev documentation

[4] GitHub - OISF/suricata: Suricata is a network Intrusion Detection System, Intrusion Prevention System and Network Security Monitoring engine developed by the OISF and the Suricata community.